

密码学

从零到现代安全系统

从基础概念、定义与推导开始
理解秘密如何被保护，身份如何被验证，
以及安全为什么总是带着条件成立。

24 个核心章节 · 9 个数学与物理附录

71 道练习与参考答案 · 12 题自测

完整 PDF 阅读版 · 公式、算例与代码示例

版本 1.0 / 2026-10-03

本版展开全部练习答案。交互计算与学习进度请使用 HTML 版。

目录

00 · 如何从零学习这门学科	4
01 · 密码学保护什么	6
02 · 比特、字节与计算	8
03 · 用安全游戏定义“破解”	10
04 · 古典密码与一次一密	12
05 · 伪随机、流密码与随机数	14
06 · 分组密码与 AES	16
07 · 工作模式与可篡改性	18
08 · 哈希函数与生日界	20
09 · MAC 与认证加密 AEAD	22
10 · KDF、密码存储与熵	24
11 · 公钥密码与混合加密	26
12 · RSA：从数论到安全编码	28
13 · Diffie–Hellman 与认证	30
14 · 椭圆曲线密码学	32
15 · 数字签名与证书	34
16 · TLS、端到端加密与协议组合	36
17 · 密钥管理与密码生命周期	38

目录 / 续

18 · 侧信道、故障与实现验证	40
19 · 实验室：从手算到库调用	42
20 · 承诺、零知识与知识证明	45
21 · 秘密分享、安全计算与同态加密	47
22 · 后量子密码与格基础	49
23 · 量子密钥分发与 BB84	51
24 · 综合设计、误区与进阶路线	53
学习复盘 · 术语表与自测	55
资料与标准 · 阅读入口	58
附录 A · 符号、集合、逻辑与证明	60
附录 B · 代数运算、指数与对数	62
附录 C · 整除、同余、逆元与中国剩余定理	64
附录 D · 概率、条件分布与统计距离	66
附录 E · 群、环、有限域与多项式	68
附录 F · 信息论与熵	70
附录 G · 向量、矩阵、线性代数与格	72
附录 H · 复杂性、归约与混合论证	74
附录 I · 量子信息与物理基础	76

00 · 如何从零学习这门学科

先知道自己要解决什么问题，再理解工具为什么有效。

这份教材的目标与边界

密码学研究如何在存在对手的环境下保护信息、验证行为并协调计算。你将学习四类能力：准确描述安全目标；手算代表性算法；理解安全证明的结构与限制；识别真实系统中原语、协议、实现和运维之间的断层。这里的“从零”指不预设密码学经验，也不预设大学数学熟练度。它仍然要求你愿意做算术、推导和练习。

这是一份覆盖本科核心、带研究生入门拓展的自学教材，不是所有密码学分支的百科全书。高级主题会给出结构、关键定义和继续深读的入口；它们的完整证明、生产实现与认证流程需要专门资料。不要把读完一份文档等同于能够设计新密码算法。

先后顺序

- 1. 读第 01—03 章，建立威胁模型、比特表示和安全定义。遇到符号时回查附录 A—D。
- 2. 读第 04—10 章，掌握对称加密、哈希、认证与密钥派生。做纸笔例题，不必先安装编程环境。
- 3. 读第 11—15 章，理解数论、公钥加密、密钥交换、椭圆曲线和签名。需要附录 C、E。
- 4. 读第 16—19 章，把原语放回协议、密钥管理和实现问题中；完成实验。
- 5. 读第 20—23 章，进入零知识、安全计算、后量子与量子密钥分发。需要附录 F—I 的部分内容。
- 6. 通过第 24 章的综合设计检查自己是否能够解释“安全在什么条件下成立”。

物理不是经典密码学的前置门槛。经典密码学主要依赖离散数学、概率和计算复杂性；量子算法与量子密钥分发才需要量子信息基础。微积分、经典力学和电磁学可帮助进一步研究硬件，但不必为学习 AES、RSA 或 TLS 先读整套物理课程。

建议节奏：24 周，每周 6—8 小时

阶段	周次	学习内容	可交付成果
基础	1—4	01—04；附录 A—D	解释安全目标，证明一次一密，计算模逆元
对称工具	5—9	05—10；附录 F	画 AEAD 数据流，解释 nonce 重用与生日界
公钥工具	10—14	11—15；附录 E	手算 RSA、DH、点加与 Schnorr
工程与协议	15—18	16—19	分析一次握手，完成篡改失败实验
进阶概念	19—22	20—23；附录 G—I	解释零知识、LWE 与 BB84 的假设边界
综合复习	23—24	24；重做错误练习	给业务场景写一份可审查的密码设计说明

这是学习安排，不是学时保证。若模运算和概率不熟，基础阶段可延长。每次学习采用“读 40 分钟 → 推导 20 分钟 → 做题 30 分钟 → 用自己的话复述 10 分钟”。阅读顺畅但不会做题，通常意味着只记住了术语。

怎样使用本文件

本 PDF 可离线阅读，支持目录跳转、PDF 书签与文本搜索。练习答案已全部展开；自测附有参考答案。交互实验在此版以静态算例呈现，实时计算、网页全文检索与学习进度请使用 HTML 版本。

严肃学习的三个习惯

- 每次说“安全”，补上对手能力、概率、参数和泄露信息。
- 把“正确性证明”“安全归约”“数学难题假设”“实现验证”分开记录。
- 遇到推荐参数和标准，查发布状态与勘误；学习版示例中的小参数只用于展示机制。

练习与参考答案

1. 如何判断自己已经掌握一章？

参考答案

合上正文，写出该章解决的问题、接口、一个失败例子与适用假设，再独立完成练习。只会背术语不能算掌握。

01 · 密码学保护什么

保密、完整性、真实性和新鲜性是不同目标。

1.1 一个业务场景

Alice 要向 Bob 发送“向供应商支付 10 万日元”。Eve 可以监听网络，Mallory 还可以修改、删除、注入消息。Alice 希望别人看不到金额，Bob 希望金额没被修改、消息确实来自有权限的人，而且不是上个月付款指令的重放。这四个问题分别需要保密性、完整性、来源认证与防重放。

目标	要阻止的事	典型工具	不自动解决的事
保密性	从传输或存储中获知明文	加密、流量填充	篡改、端点感染、消息长度
完整性与认证	伪造被接受的消息	MAC、AEAD、签名	重放、发件人权限是否合理
身份认证	冒充某个实体	认证密钥交换、凭据	被认证者是否诚实
新鲜性	接受旧消息	序号、挑战、时间窗与状态	序号的持久化和分布式一致性
可用性	资源被耗尽或服务被中断	系统容量、防滥用机制	仅靠加密不能保证可用性

1.2 四层模型

原语是 AES、哈希、签名这样的基本工具；方案把原语组成具有某项安全性质的接口，如 AEAD；协议规定参与者交换什么、何时接受，如 TLS；系统还包括证书、权限、备份、日志、更新与人员操作。一个原语被广泛研究，不能直接推出任何使用它的系统都安全。

密码算法通常公开。Kerckhoffs 原则要求安全主要依赖秘密密钥，而不是隐藏算法。公开使研究者能够分析，也使密钥可以在泄露后更换。它不表示实现细节永远没有攻击价值，而是反对把“别人不知道算法”当作根本保证。

1.3 威胁模型怎么写

明确资产、参与者、信任根、对手权限、可观察信息和成功条件。例如：攻击者可读取对象存储并修改密文，但拿不到 KMS 主密钥；客户端和服务端没有被攻陷；目标是使攻击者不能恢复内容或让篡改被当作合法版本。若攻击者能控制解密服务器，磁盘加密通常不能保护正在使用的明文。

被动对手只观察；主动对手可干预。诚实但好奇的参与者遵循协议却试图推断秘密；恶意参与者可以任意偏离。静态腐化提前确定被攻陷对象；自适应腐化可在执行过程中选择。模型越弱，证明越容易，适用范围也越窄。

1.4 编码、压缩和隐藏

Base64 把字节转换为易传输的文本，任何人都可逆；压缩减少冗余，不靠密钥；隐写把消息存在性藏起来；哈希通常不可逆但不具有保密接口。把 API key 做 Base64 后放进前端，仍然把它公开了。把短手机号做 SHA-256，也可能被枚举恢复。

判别例：一份文件有 SHA-256 摘要，如果攻击者能同时替换文件和摘要，校验仍然通过。摘要只在可信渠道给出预期值时提供对照；来自同一不可信位置的摘要不能自己建立可信性。

1.5 安全强度不是一个万能数字

“128 位安全”通常指最有效已知通用攻击所需工作量的数量级接近 2^{128} ，不是保证失败概率恒为 2^{-128} 。查询次数、用户数、标签截断、模型和侧信道都会改变有效安全性。RSA 2048 位模数也不等于 2048 位安全；不同结构不能直接用密钥长度比较。

练习与参考答案

1. 加密了付款指令，为什么 Bob 仍不能确信金额未被改动？

参考答案

加密本身不一定抗篡改，某些模式可以定向翻转明文比特。需要消息认证或 AEAD，此外还要序号或唯一事务 ID 防止重放。

2. 服务器保存“文件 + 哈希”，是否能对抗恶意存储管理员？

参考答案

若管理员能一起替换二者就不能。可用受保护密钥生成 MAC，或由可信签名密钥签名版本信息、文件哈希和上下文。

02 · 比特、字节与计算

密码算法操作的是精确的表示，不是自然语言意义。

需要时回查：附录 A附录 B

2.1 从字符到字节

一个 bit 是 0 或 1；一个 byte 是 8 bits，可表示 0—255。文本先通过 UTF-8 等编码变为字节。“A”是十六进制 41；中文字符通常占多个字节。十六进制每位对应 4 bits，因此一个字节写成两位十六进制。字符串长度、字符数和字节长度不可混用。

整数也需要约定表示：长度、大小端、符号位。数值 258 写为两个字节，大端是 01 02，小端是 02 01。签名的是字节序列；两个 JSON 对象语义相同但空格和字段顺序不同，直接签名得到的结果也不同。规范化、长度前缀和版本化编码属于协议的一部分。

2.2 异或 XOR

异或记作 $\oplus$ ：相同位得到 0，不同位得到 1。它相当于每个位上的模 2 加法。

a	b	$a \oplus b$
0	0	0
0	1	1
1	0	1
1	1	0

$$a \oplus 0 = a ; a \oplus a = 0 ; (a \oplus b) \oplus b = a$$

例如 $10110100 \oplus 01101101 = 11011001$ 。再与 01101101 异或就回到 10110100。流加密依赖这种可逆关系，安全则取决于掩码是否不可预测、是否被重复使用。

2.3 加法、移位和循环移位

机器字常做模 2^w 加法：8 位的 $250 + 10$ 变为 4。移位会丢弃移出位；循环移位会把它们移回另一端。ChaCha 的核心组合是加法、循环移位和异或，简称 ARX。异或的线性性和带进位加法的非线性相互补充。

2.4 算法、随机性和复杂度

算法是精确的步骤；随机算法还接收随机比特。同一密钥和明文的加密可以因为随机性不同而输出不同密文。讨论复杂度时 n 通常是输入的比特长度，而不是输入整数的数值。例如整数 N 的长度约为 $\log_2 N$ ，枚举到 N 会是对输入长度指数级的操作。

计算 $a^e \bmod n$ 不必先生成巨大的 a^e 。平方乘算法逐位处理指数，每次取模。 $e=13=1101_2$ 时，可计算 a^2 、 a^4 、 a^8 ，再乘 $a^8 a^4 a$ 。大约需要 $O(\log e)$ 次模乘；不能因此说总比特复杂度就是 $O(\log e)$ ，模乘本身也有成本。

2.5 教学算法：快速模幂

```
def modexp(a, e, n):
    if n <= 0 or e < 0:
        raise ValueError("要求 n > 0 且 e ≥ 0")
    result = 1 % n
    a %= n
    while e:
        if e & 1:
            result = (result * a) % n
        a = (a * a) % n
        e >>= 1
    return result
```

这是学习代码。它的执行分支依赖 e 的比特；如果 e 是私钥，可能产生计时或缓存泄露。数学正确与恒定时间是两个不同问题。

练习与参考答案

1. 计算十六进制 $3a \oplus c5$ 。

参考答案

$3a$ 是 00111010 ， $c5$ 是 11000101 ；异或为 11111111 ，即 ff 。

2. 计算 $7^{13} \bmod 23$ 。

参考答案

$7^2 \equiv 3$ ， $7^4 \equiv 9$ ， $7^8 \equiv 12$ ； $7^{13} \equiv 12 \times 9 \times 7 \equiv 20 \pmod{23}$ 。

03 · 用安全游戏定义“破解”

不能靠“看起来随机”代替可检验的安全目标。

需要时回查：附录 A附录 D附录 H

3.1 加密方案的接口与正确性

对称加密方案由 Gen、Enc、Dec 组成。Gen(1^λ) 输出密钥 k ；Enc(k,m) 输出密文 c ；Dec(k,c) 恢复 m 或报错 $\perp$ 。安全参数 λ 控制密钥长度或其他参数。正确性要求合法密文能够恢复明文；它不要求任意攻击者构造的密文都能解密成功。

$$\Pr[\text{Dec}(k, \text{Enc}(k,m)) = m] = 1$$

有些方案允许可忽略的正确性错误，应在定义中明确。公开密钥方案使用 pk 加密、 sk 解密；MAC 使用同一秘密密钥认证与验证；签名用私钥签署、公钥验证。

3.2 IND-CPA：选择明文不可区分

1. 挑战者生成秘密密钥，对手可以请求所选明文的加密。
2. 对手提交两个等长消息 m_0 、 m_1 。
3. 挑战者均匀选 $b \in \{0,1\}$ ，返回 $c^* = \text{Enc}(k, m_b)$ 。
4. 对手继续进行允许的查询，输出猜测 b' 。

$$\text{Adv} = |\Pr[b' = b] - 1/2|$$

这里采用“偏离 $1/2$ ”的优势定义，另一常见约定乘以 2。安全意味着任何概率多项式时间对手的优势对 λ 都可忽略。等长约束排除消息长度泄露这个显然的区分器；实际系统若要隐藏长度，需要额外填充与流量措施。

确定性对称加密在可重复查询的普通 CPA 模型下不能满足这个定义：对手先请求 $\text{Enc}(k, m_0)$ ，再比较挑战密文即可。但在特殊消息分布或不同安全定义中，确定性加密可以有另行分析的用途；不要把结论脱离模型。

3.3 IND-CCA：对手还能请求解密

自适应选择密文安全通常称 IND-CCA2：对手在挑战前后可调用解密接口，但不能提交挑战密文本身。若允许直接解密挑战，游戏就失去意义。它关注密文被恶意修改后是否能够帮助攻击者区分消息。现实中的“填充错误”“认证错误”和时间差都可能成为解密预言机。

3.4 伪造安全与隐私安全不同

MAC 和签名的常见目标是 EUF-CMA：对手可请求所选消息的认证标签或签名，但最后不能为一个从未请求过的消息给出有效结果。强不可伪造还会禁止对已签署消息制造一个新的有效签名。签名可能完全公开消息，仍然满足不可伪造性。

3.5 计算安全、统计安全与完美安全

完美安全要求观察值分布完全一致，不限制算力。统计安全允许很小的分布差异，也不靠计算限制。计算安全只要求有效对手无法区分，即便两种分布从无限算力视角并不相同。现代高效加密通常属于计算安全，依赖数学困难性或伪随机假设。

3.6 可忽略函数与具体安全界

$\text{negl}(\lambda)$ 比任何逆多项式最终都小。 $2^{-\lambda}$ 可忽略； $1/\lambda^2$ 不可忽略，因为对 λ^3 这个多项式就不够小。渐近结论方便理论组合，但部署需要具体界：攻击时间 t 、查询次数 q 、消息总量 σ 、优势 ε ，以及多用户和生命周期限制。

3.7 安全归约到底证明什么

假设存在攻击方案的对手 A ，构造求解难题的算法 B ： B 接收难题实例，把它嵌入 A 的游戏，利用 A 的输出解题。若 $\text{Adv}_B \geq \text{Adv}_A/L - \delta$ ，就得到 $\text{Adv}_A \leq L \cdot \text{Adv}_B + L\delta$ 。 L 是归约损失，可能与查询数有关。归约不证明难题本身绝对困难，也不自动覆盖库实现、密钥泄露或不在模型内的侧信道。

模型检查：随机预言机模型把哈希理想化为可查询的随机函数；真实哈希是固定算法。在该模型中的证明是有价值的条件性保证，但不等于任何替换哈希的方法都得到无条件安全。

练习与参考答案

1. 为什么挑战消息要求等长？

参考答案

若密文长度暴露明文长度，选不同长度消息就能无须破解区分。等长游戏隔离内容保密；它没有承诺隐藏长度。

2. “方案安全归约到分解问题”是否等于“已证明分解困难”？

参考答案

不是。归约把方案安全关联到假设，困难性假设仍需研究；还要检查归约方向、损失和所用模型。

04 · 古典密码与一次一密

从可破解的结构中，理解真正的安全要求。

需要时回查：附录 C附录 D附录 F

4.1 凯撒与仿射密码

把字母映射为 0—25。凯撒加密 $c=m+k \bmod 26$ ，只有 26 个密钥，穷举即可。仿射加密 $c=am+b \bmod 26$ ，要求 $\gcd(a,26)=1$ ，否则不同明文可能映射到同一密文，无法唯一解密。合法 a 有 $\phi(26)=12$ 个，因此总密钥只有 312 个。

一般单表替换有 $26!$ 种映射，看似巨大，但保持字母频率和相邻模式。自然语言冗余使统计攻击有效。这说明密钥空间大不是充分条件；攻击者可能绕过穷举利用结构。

4.2 维吉尼亚与重复周期

维吉尼亚用重复的密钥字母控制移位。若周期是 l ，把密文每 l 个字符分组，每组近似一个凯撒密码。重复片段与统计相关性可帮助猜周期。它仍然没有阻止选择明文攻击：已知明文与密文相减可暴露对应位置的密钥流。

4.3 一次一密 OTP 的机制

$K \leftarrow \text{均匀 } \{0,1\}^n$; $C=M \oplus K$; $M=C \oplus K$

要求密钥与消息一样长、均匀随机、独立于消息、秘密保管且每段只用一次。对于任意 m, c ，恰有一个 $k=m \oplus c$ ，因此 $\Pr[C=c \mid M=m]=2^{-n}$ 。分布不依赖 m ，于是观察 C 不改变对 M 的先验判断： $\Pr[M=m \mid C=c]=\Pr[M=m]$ 。这就是完美保密，成立于密钥真正随机且一次使用的前提。

4.4 为什么不能重用

$C_1 \oplus C_2 = (M_1 \oplus K) \oplus (M_2 \oplus K) = M_1 \oplus M_2$

攻击者不一定立即得到两个完整明文，但明文之间的关系已被暴露。有一条已知消息时， $K=C_1 \oplus M_1$ ，可以恢复另一条。在自然语言中还可猜片段并检验两边是否合理。随机密钥第一次安全，不会使重复使用安全。

4.5 完美保密不提供完整性

攻击者把 C 改为 $C'=C \oplus \Delta$ ，接收者解密为 $M'=M \oplus \Delta$ 。攻击者甚至无须知道 M 即可翻转选定位置。一次一密需要配合独立的认证方案，且认证密钥管理同样重要。

4.6 Shannon 的限制

在正确解密与完美保密的适当条件下，密钥的不确定性至少要覆盖消息的不确定性： $H(K) \geq H(M)$ 。等长均匀消息下，密钥空间不能比消息空间小。现代流密码用短密钥生成很长掩码，因此必然放弃无条件完美保密，转而依赖计算不可区分性。

8 位算例： $M=10110100$ ， $K=01101101$ ， $C=11011001$ 。若第二条消息 $M_2=00001111$ 重用 K ， $C_2=01100010$ 。两条密文异或为 10111011 ，与 $M \oplus M_2$ 一致。

练习与参考答案

1. 仿射密码 $a=2$ 、 $b=3$ 在模 26 下为何不能唯一解密？

参考答案

$\gcd(2, 26)=2$ 。 $m=0$ 和 $m=13$ 都得到 $c=3$ ，映射不是一一对应，2 在模 26 下没有逆元。

2. 证明 OTP 的均匀密钥让密文分布独立于明文。

参考答案

固定 m 和 c ，唯一密钥是 $m \oplus c$ ；均匀密钥取到它的概率是 2^{-n} ，对所有 m 都一样。用贝叶斯公式即可得到后验等于先验。

05 · 伪随机、流密码与随机数

短密钥能保护长消息，靠的是计算上的不可预测。

需要时回查：附录 D附录 H

5.1 PRG、PRF 和 PRP

伪随机生成器 PRG 把短随机种子扩展为更长的比特串，要求有效观察者无法区分输出与真正均匀的串。输出只有至多 2^{λ} 种可能，信息论上绝非真正均匀；计算限制是核心。伪随机函数 PRF 是带密钥的函数族，连同查询访问时近似随机函数。伪随机置换 PRP 是固定长度集合上的可逆置换族，近似随机置换。AES 被用作 PRP；HMAC 常作为 PRF 使用。

统计测试只能找出某些明显缺陷，不能证明伪随机安全。一个序列可以通过频率测试却完全可预测，例如公开算法与公开种子生成的输出。

5.2 流密码

$S = \text{Stream}(k, \text{nonce})$; $C = M \oplus S$

nonce 是每个密钥下不能重复的输入，通常公开传输。它不是另一个秘密密钥。密钥相同而 nonce 不同时，应产生不同、计算上不可预测的流。把相同 nonce 用在两个消息上会回到“两次一密”问题。计数器也有上限，溢出不能默默回到零。

5.3 ChaCha20 的直觉

ChaCha20 在 32 位字上反复混合：加法产生进位，异或把信息合并，循环移位搬动比特。其 quarter-round 轮换更新四个字；IETF 版本使用 256 位密钥、96 位 nonce 和 32 位块计数器。具体轮数、布局 and 测试向量见 RFC 8439 [3]。核心流密码没有认证；ChaCha20-Poly1305 才是组合后的 AEAD。这里不把完整规范改写为教学自制实现。

5.4 真随机与 CSPRNG

操作系统从熵源初始化密码安全伪随机数生成器，再高效输出随机字节。熵来自不可预测的观测，并不等于“数据很复杂”。时间戳、进程号和随机字符串外观都不构成足够熵。普通模拟用 PRNG 可能在观察足够输出后恢复状态，不能用于密钥。

安全随机数接口还涉及启动时熵不足、虚拟机克隆、容器复制、设备回滚和随机状态泄露。稳健系统使用成熟的系统随机接口，避免自行从鼠标坐标或当前时间拼种子。Python 中用 secrets 或 os.urandom；random 模块适合模拟，不适合生成秘密密钥。

5.5 nonce、IV、salt 不是同一概念

名称	通常公开？	关键要求	例子
nonce	是	算法要求的唯一性，有时还有其他限制	GCM 每密钥唯一
IV	是	依模式而变，可能要求不可预测	CBC 加密 IV 应不可预测
salt	是	区分实例，降低预计算和批量摊销	密码哈希每账户独立随机 salt
key	否	足够熵、秘密性、生命周期受控	AES 密钥

唯一性可以由计数器保证，但要考虑崩溃后持久化、多个写入节点与恢复旧备份。随机 nonce 只提供概率唯一性，随着使用次数会出现生日碰撞风险。选择方式是工程设计，不是“随机越多越安全”的口号。

练习与参考答案

1. 随机生成 96 位 nonce 是否永远不会重复？

参考答案

不会。 q 次采样的碰撞概率近似 $q(q-1)/2^{97}$ ， q 增大风险累积。需要每密钥调用量限制、密钥轮换或可靠的唯一分配机制。

2. 为什么普通 random 输出不能用于密钥？

参考答案

它面向模拟与可复现性，通常没有密码安全的状态恢复抵抗保证。输出外观看似随机不能说明攻击者无法预测。

06 · 分组密码与 AES

固定长度的可逆混合，是长消息加密的基础部件。

需要时回查：附录 E

6.1 分组密码的接口

$E_k: \{0,1\}^n \rightarrow \{0,1\}^n$ 是在每个密钥下的置换， D_k 是逆。明文不同、密钥固定时，输出块不能碰撞，否则无法唯一解密。它只定义单块变换；消息分块、nonce、填充和认证由模式处理。

6.2 混淆、扩散与轮结构

混淆使密钥与输出的关系难以分析；扩散把局部输入影响传播到多处。代换置换网络把非线性小单元与线性混合交替使用；Feistel 网络即使轮函数不可逆，也可利用结构整体可逆。雪崩效应指小输入变化带来许多输出位变化，但它是有用特征，不是安全证明。

6.3 AES 的骨架

AES 的块长为 128 位。密钥长度 128、192、256 位对应 10、12、14 轮。128 位输入排成 4×4 字节状态，先 AddRoundKey，然后常规轮执行 SubBytes、ShiftRows、MixColumns、AddRoundKey，最后一轮省略 MixColumns。密钥扩展生成每轮使用的轮密钥。标准定义见 FIPS 197 [1]。

- **SubBytes**：字节进入非线性 S-box。其构造涉及 $GF(2^8)$ 上的乘法逆元和仿射变换，零另行约定。
- **ShiftRows**：各行按不同偏移量循环移动，把列之间的信息连接起来。
- **MixColumns**：每列经有限域中的线性变换，改变一个字节会传播到多个字节。
- **AddRoundKey**：状态与轮密钥异或，把秘密材料注入运算。

6.4 为何有限域乘法不等于整数乘法

字节可视为二进制多项式。加法是 XOR，乘法先做多项式乘法，再模 $x^8+x^4+x^3+x+1$ 约化。例如 $xtime(0x57)=0xae$ ； $xtime(0x83)=0x1d$ ，因为左移得到 $0x106$ 后要按约化多项式消去最高项。附录 E 会展开这个运算。

6.5 差分 and 线性分析的概念

差分分析研究输入差分如何以特定概率转化为输出差分；线性分析寻找输入、输出与密钥位之间具有偏差的线性关系。设计者要让跨多轮的有利轨迹需要足够多的活跃非线性单元。不能通过自己测试几个随机输入，推断已经排除了这些攻击。

6.6 DES 与历史教训

DES 的 56 位有效密钥已经不足以抵抗现代穷举；64 位块长也使大量数据下的碰撞风险更早显现。3DES

延长密钥但没有改变块长。它们适合学习历史结构与退役问题，不应作为新系统的默认设计。

6.7 安全实现

传统查表实现的索引可能依赖秘密，从缓存命中差异泄露信息。硬件指令、位切片和经过审查的实现可减少这类风险，但仍需检查运行平台。AES-256 并不能补偿密钥被日志记录、nonce 重复或未认证密文的问题。

练习与参考答案

1. AES-256 是否每次处理 256 位明文块？

参考答案

不是。AES 的块长始终是 128 位，256 指密钥长度；长消息如何处理由模式决定。

2. 只有可逆的线性变换和异或轮密钥，为何不够？

参考答案

多个仿射变换的复合仍是仿射变换，可被线性代数重建。非线性单元是避免整体退化为易解线性关系的重要组成部分。

07 · 工作模式与可篡改性

模式决定一个分组密码如何变成消息加密方案。

需要时回查：附录 A

7.1 ECB 为什么泄露结构

$$C_i = E_k(M_i)$$

同一密钥下相同明文块产生相同密文块。文件中重复的格式、表格和图像区域因此可被识别。单块置换难破解，不意味着逐块独立处理的长消息保密。普通多消息保密用途不应使用 ECB。

7.2 CBC：链式依赖

$$C_0 = IV ; C_i = E_k(M_i \oplus C_{i-1})$$

$$M_i = D_k(C_i) \oplus C_{i-1}$$

消息必须按块处理，不足整块时常需填充。对 16 字节块，PKCS#7 若缺 5 字节，就补五个 0x05；若恰好整块，仍补一整块 0x10，以免解码歧义。加密的 IV 应不可预测；如果攻击者能事先预测 IV，可能构造区分攻击。IV 也要纳入认证。

修改 C_{i-1} 会在 M_i 中引入同样 XOR 差分，并通常破坏 M_{i-1} 。若修改 IV，就能改第一块而没有前一块损坏。CBC 加密本身不提供完整性。

7.3 填充预言机

假设服务接收任意 CBC 密文，并通过错误信息或时间差区分“填充有效”与“填充无效”。攻击者可反复修改前一块，推断 $D_k(C_i)$ 的末字节，再逐字节扩展。密码算法没有被破解，但解密接口泄露了明文约束。统一错误只是缓解的一部分；优先选择正确使用的 AEAD，避免先处理未认证明文。

7.4 CTR：把分组密码变成密钥流

$$S_i = E_k(\text{Encode}(\text{nonce}, \text{counter}_i)) ; C_i = M_i \oplus S_i$$

可以并行、无需填充、支持随机访问。但每个密钥下所有输入计数块必须唯一；nonce 与 counter 的编码必须无歧义，counter 不得溢出。修改密文某位直接修改明文对应位。CTR 只解决保密，必须配合认证。

7.5 模式比较

模式	关键公开输入要求	填充	认证	主要风险
ECB	无 IV	通常需要	无	暴露重复块
CBC	加密 IV 不可预测	通常需要	无	篡改、填充预言机
CTR	计数块每密钥不重复	不需要	无	密钥流重用、比特翻转
GCM	nonce 每密钥唯一，遵循用量限制	不需要	有	nonce 重用、错误的标签处理
XTS	按存储单元定义 tweak	特殊处理	无	无法独立防止恶意扇区篡改

XTS 面向存储介质，tweak 绑定位置并使同值块的结果与位置有关，但不是通用 AEAD。磁盘加密与完整性保护是不同设计维度。

7.6 组合顺序

Encrypt-then-MAC 通常先加密，再对协议上下文、nonce 和密文生成 MAC，接收方先验 MAC 再解密。它在相应假设与正确编码下容易得到良好的组合安全性。MAC-then-Encrypt、Encrypt-and-MAC 不能仅靠名字判断安全，必须检查具体构造与错误处理。工程上直接使用标准 AEAD 接口更可靠。

练习与参考答案

1. CTR 密文中某字节异或 0x01 后，明文怎样变化？

参考答案

对应明文字节最低位翻转。CTR 没有认证时，接收方可能无从检测。

2. CBC 恰好 16 字节的消息使用 PKCS#7，应补多少字节？

参考答案

补 16 个值为 0x10 的字节。否则末尾看似合法填充的真实数据会引起歧义。

08 · 哈希函数与生日界

摘要用于承诺数据的指纹，但它不自动建立信任。

需要时回查：附录 B附录 D

8.1 三种不同难题

哈希 H 把任意长度输入映射到固定 n 位输出。因为输入更多，碰撞必然存在，安全目标是难以有效找到。

性质	攻击者给定什么	要找到什么	理想 n 位哈希通用工作量
原像抵抗	目标摘要 y	x 使 H(x)=y	约 2^n
第二原像抵抗	特定消息 x	$x' \neq x$ 且 $H(x')=H(x)$	典型固定消息情形约 2^n
碰撞抵抗	自由选择输入	任意 $x \neq x'$ ，摘要相同	约 $2^{n/2}$

表中的估计是理想化通用量级，真实结构、超长消息和多目标场景需要单独分析。碰撞攻击者可选择两边，第二原像攻击者一边被固定，所以问题不同。

8.2 生日界推导

设 $N=2^n$ ，q 个输出独立均匀。没有碰撞的概率是 $\prod_{i=0}^{q-1}(1-i/N)$ 。当 q 相比 N 小时， $\ln(1-x) \approx -x$ ，于是无碰撞概率近似 $\exp(-q(q-1)/(2N))$ ，碰撞概率近似 $1-\exp(-q(q-1)/(2N))$ 。约 $q=1.177\sqrt{N}$ 时达到 50%。这也是随机 nonce 的风险模型。

256 位摘要的通用碰撞工作量约为 2^{128} ，而不是 2^{256} 。不可逆并不是信息完全丢失：对低熵输入，攻击者可以逐个猜候选值、计算摘要并比较。

8.3 两类结构

Merkle-Damgård 把消息分块，通过压缩函数反复更新内部状态，并使用含长度的填充。部分这种结构允许在知道 H(m) 和消息长度后算出 $H(m\parallel\text{pad}\parallel\text{suffix})$ ，称长度扩展。海绵结构维护较大状态，分吸收与挤出阶段；SHA-3 属于这一路线。不同结构的攻击与安全条件不能简单混同。

8.4 为什么 H(key||message) 不是通用 MAC

对可长度扩展的哈希，攻击者可能从标签推导带扩展消息的新标签。即使换一种拼接顺序，也不能凭直觉得到所有需要的伪造安全。使用专门构造 HMAC，并严格编码消息。碰撞抵抗与 MAC 的 PRF/伪造性质不是同一个定义。

8.5 Merkle 树

把数据块哈希为叶子，父节点哈希两个子节点，最终根摘要承诺整批数据。一个成员证明只需给出从叶到根路径上的兄弟摘要，大小 $O(\log n)$ 。验证者还必须拥有可信根，明确叶子排序和编码规则。给叶和内节点不同前缀，如 $H(0x00\parallel\text{leaf})$ 与 $H(0x01\parallel\text{left}\parallel\text{right})$ ，可减少结构歧义。

8.6 哈希能做与不能做

哈希可用于版本指纹、内容寻址、承诺与签名的消息预处理。它不隐藏短输入、不加密文件、不证明谁创建了文件、不证明内容正确。MD5 和 SHA-1 的碰撞安全不足，不适合新的依赖碰撞抵抗的设计。选择算法时必须按具体用途检查标准与应用要求。

练习与参考答案

1. 理想 128 位摘要的通用碰撞攻击量级？

参考答案

约 2^{64} 次哈希；若要求约 128 位碰撞安全，需要约 256 位输出的合适哈希。

2. 为什么“手机号做 SHA-256”未必匿名？

参考答案

手机号候选集合远小于 2^{256} ，可枚举候选并匹配摘要。输出长不代表输入有足够熵；还需分析跨表关联与可访问的验证接口。

09 · MAC 与认证加密 AEAD

消息被接受之前，必须先验证它来自允许的密钥持有者。

需要时回查：附录 D附录 E

9.1 MAC 的能力与边界

$\text{Tag}(k,m)$ 生成认证标签； $\text{Verify}(k,m,t)$ 决定接受或拒绝。双方共享秘密密钥，因而双方都能生成合法标签。MAC 能提供相对于密钥持有者集合的来源认证，不能向第三方证明一定是其中某个人签发。这一点与公钥签名不同。

9.2 HMAC

$$\text{HMAC}(K,m)=H((K'\oplus\text{opad}) \parallel H((K'\oplus\text{ipad}) \parallel m))$$

K' 按哈希块长规范化，ipad 和 opad 是不同的固定填充值。内外两层与独立前缀处理避免直接使用前缀哈希的一些结构问题。标签长度必须足够，比较应使用抗计时泄露的接口。简单提前返回的逐字节比较可能暴露匹配前缀。

9.3 AEAD 的接口

$$(C,T)=\text{Seal}(K,N,M,A)$$

$$M \text{ 或 } \perp = \text{Open}(K,N,C,A,T)$$

K 是密钥， N 是 nonce， M 是保密内容， A 是 associated data（关联数据）。 A 不被加密但被认证，例如协议版本、用户 ID、记录类型和序号。改变 A 、 N 、 C 或 T 应使验证失败。AEAD 通常同时追求保密与密文完整性，但接口使用限制仍要满足。

业务绑定：加密工资单时，把租户 ID、员工 ID、版本号和对象用途放入无歧义 AAD。否则一份完全合法的密文可能被搬到另一租户、另一字段或旧版本位置，标签仍然有效。这叫上下文错配，不要求攻击者破解算法。

9.4 GCM 的组成

AES-GCM 以计数器方式加密，再用 $\text{GF}(2^{128})$ 上的 GHASH 认证关联数据与密文，并对长度编码。认证子密钥 $H=E_k(0^{128})$ ，标签还由与 nonce 相关的 AES 输出掩蔽。机制与使用要求见 SP 800-38D [2]。重复 nonce 会重用流，并泄露认证关系，可能使伪造变得可行；不是“只泄露一点随机性”。

9.5 ChaCha20-Poly1305

ChaCha20 负责流加密，Poly1305 是用一次性密钥的认证器；组合规范从密钥和 nonce 派生对应认证材料，并规定消息布局。不要把裸 Poly1305 一次性密钥随意重用。AEAD 不允许因不同用途共享同一密钥流。

9.6 标签、用量与错误处理

若标签近似均匀且没有结构性攻击， t 位标签面对 v 次独立伪造尝试，成功概率粗略约 $v/2^t$ ；真实安全界还有消息量等项。截断标签不是免费优化。认证失败时，不得把未认证明文交给业务逻辑；不要让“先读取命令再查标签”产生副作用。

AEAD 不阻止合法密文被重放，也不隐去长度。大型文件分块时，每块需要独立 nonce，并在 AAD 中绑定文件 ID、块序号与总长度或最终块信息，以检测重排、删除、拼接和截断。只有逐块验签而没有完整性终止条件，可能接受不完整文件。

9.7 nonce 误用抵抗

SIV 系列构造尝试降低 nonce 重用的灾难性后果，但通常会在重复条件下泄露相等性，有不同性能与安全界。误用抵抗不是鼓励重复，也不能自动解决回滚与重放。必须按选定方案的规范分析。

练习与参考答案

1. AAD 能放机密的患者姓名吗？

参考答案

AAD 被认证但不加密，可能明文暴露。机密姓名应放入加密正文；AAD 可用不敏感标识，但仍要评估关联泄露。

2. 有效 AEAD 密文再次发送是否会自动失败？

参考答案

不会，若状态和输入相同它通常再次通过。协议必须用序号、唯一事务 ID、接收窗口及持久化状态防重放。

10 · KDF、密码存储与熵

密钥派生和口令加固解决两类不同问题。

需要时回查：附录 F

10.1 人类口令不是均匀密钥

用户口令分布高度不均匀，“复杂度规则”也不能使用户选择真正均匀。攻击者优先尝试常用词、泄露口令和有针对性的组合。对称密钥应由安全随机接口生成；人类口令应交给专门的密码哈希或口令 KDF。

10.2 salt 的作用

每个账户用独立随机 salt，使相同口令产生不同记录，并阻止为所有账户共用一张预计算表。salt 不需要保密，通常与算法、参数、哈希值一起存储。salt 不增加用户口令本身的熵；攻击者仍能针对单账户离线猜测。

10.3 工作因子与内存困难性

口令哈希让每次猜测消耗时间或内存，以提高批量攻击成本。Argon2id 同时考虑内存成本、迭代次数和并行度，规范见 RFC 9106 [6]。不能给所有服务器套同一组参数：需要在目标硬件上测量延迟、内存、并发与拒绝服务风险。记录参数版本，允许登录成功时逐步升级。

登录限速和 MFA 抑制在线猜测，却不能阻止拿到数据库后离线猜测。pepper 是额外受保护的秘密材料，与公开 salt 不同；它增加运维、轮换和可用性要求，不能当作盐的替代。

10.4 HKDF 的两阶段

```
PRK=HMAC(salt,IKM)
OKM=HKDF-Expand(PRK,info,L)
```

Extract 从输入密钥材料 IKM 得到伪随机密钥 PRK；Expand 根据上下文 info 生成指定长度材料。HKDF 的具体格式和限制见 RFC 5869 [5]。它适合从已有秘密材料派生会话子密钥；不是提高弱口令猜测成本的内存困难算法。

10.5 域分离与用途分离

从同一主秘密派生上传密钥、下载密钥、认证密钥时，在 info 中放不同标签和协议上下文。这样不同接口不会无意共用材料。域分离必须有确定编码，避免“ab”||“c”和“a”||“bc”相同。可用长度前缀或固定结构；不能只靠人眼认为标签不同。

10.6 熵与实际猜测

若从集合中均匀选取， N 种可能给出 $\log_2 N$ 位熵。六位十进制验证码只有约 19.93 位，而且通常有效时间短、必须限速。字符串包含大小写数字并不意味着每一位真的均匀。最小熵 $H_\infty = -\log_2(\max_x \Pr[X=x])$ 强调最容易猜中的值。

10.7 密码重置与恢复

重置令牌应足够随机、短期有效、一次性、绑定账户和用途；服务器通常存其摘要而非原始值。重置成功后使旧令牌失效，并分析已有会话是否要撤销。账户恢复渠道往往比主密码更弱，密码学选型不能弥补可被社工绕过的流程。

练习与参考答案

1. HKDF 能直接把“123456”变成抗离线猜测的强密钥吗？

参考答案

不能。输出可以很长，但攻击者仍可枚举少量口令候选。应先使用合适的口令 KDF 加固，再按具体方案派生用途密钥。

2. 两个用户密码相同，独立 salt 如何影响泄露后的攻击？

参考答案

记录通常不同，攻击者不能直接判定相同密码，也不能复用同一张无盐预计算表；仍可逐账户尝试候选口令。

11 · 公钥密码与混合加密

公钥消除了事先共享加密密钥的需要，却引入公钥真实性问题。

需要时回查：附录 C附录 E

11.1 公钥接口

Gen 输出 (pk, sk) ，Enc (pk, m) 输出密文，Dec (sk, c) 恢复消息。任何人可使用 pk 加密，因此加密不证明发件人身份。私钥拥有者能解密，也不表示只有某一个合法业务用户能看到明文；授权仍是系统责任。

发布公钥不等于建立信任。如果 Mallory 把自己的公钥替换成“Bob 的公钥”，Alice 会把秘密加密给 Mallory。证书、预先核验指纹、可信目录和透明日志等机制处理公钥与身份的绑定。

11.2 单向函数与陷门

单向函数易算、难以逆。陷门单向函数在拥有额外秘密时容易逆。RSA 的幂运算是学习陷门直觉的例子，但实际公钥加密不等于直接对消息做陷门变换。随机化编码与选择密文抵抗仍然必要。

11.3 为什么用混合加密

公钥操作相对昂贵，消息长度和结构也有限制。常见架构是先建立一个短共享秘密，经过 KDF 派生对称密钥，再用 AEAD 加密大文件。这样把公钥的分发优势与对称算法的高吞吐结合。

```
KEM.KeyGen  $\rightarrow (pk, sk)$ 
KEM.Encaps(pk)  $\rightarrow (enc, z)$ 
KEM.Decaps(sk, enc)  $\rightarrow z$ 
K = KDF(z, context) ; (C, T) = AEAD.Seal(K, N, M, A)
```

KEM 是密钥封装机制；封装输出一个公开封装值 enc 与共享秘密 z ，接收者解封装得到 z 。它不是“用公钥加密任意用户指定字符串”的通用消息加密接口。KEM 与 DEM 的组合还需要明确安全模型和上下文绑定。

11.4 混合方案必须绑定的内容

协议版本、算法标识、接收者或公钥标识、封装值与用途都应按规范进入密钥派生或认证上下文。否则可能发生跨协议或接收者错配。算法协商不能接受攻击者随意降级；未知字段的处理和解析顺序也会影响安全。

11.5 HPKE 的学习位置

Hybrid Public Key Encryption 将 KEM、KDF 和 AEAD 组合成统一框架，见 RFC 9180 [10]。不同模式提供不同发送者认证能力。不要看到“HPKE”就默认具备签名、防重放或会话前向保密；这些性质取决于模式、密钥生命周期和应用协议。

11.6 公钥密码的困难性家族

家族	代表问题	典型用途	注意
整数分解 / RSA	分解大合数、RSA 逆运算	加密、签名	难题之间不能未经证明视为等价
离散对数	DLP、CDH、DDH	密钥交换、签名	不同群中假设可能不同
格	LWE、SIS 及模块版本	后量子 KEM、签名	噪声与参数共同决定正确性和安全
哈希	原像、碰撞及相关结构假设	哈希签名	有状态与无状态方案要区分

11.7 ElGamal：一个具体的随机化方案

在素数阶群 G 中，私钥 x ，公钥 $Y=g^x$ 。对群元素消息 M ，选新随机 r ，输出 $(C_1,C_2)=(g^r,M\cdot Y^r)$ 。解密算 $M=C_2/C_1^x$ 。正确性来自 $Y^r=g^{xr}=C_1^x$ 。随机 r 让同一消息多次加密通常不同；在适当 DDH 假设下可证明其 CPA 安全。

它可篡改：把 C_2 乘一个群元素 Δ ，解密消息就变成 $M\Delta$ ，所以没有普通 CCA 抵抗。实际任意字节消息通常使用混合加密，不把字节随意塞进群里。ElGamal 也与数学上相关的签名构造不同，不能只按名字混用接口。

练习与参考答案

1. 别人能用 Bob 的公钥加密，是否能让 Bob 确认发送者是 Alice？

参考答案

不能。任何人都能生成密文；需要签名或具有发送者认证的协议，同时可信绑定 Alice 的公钥。

2. KEM 与 AEAD 各负责什么？

参考答案

KEM 建立短共享秘密，KDF 派生用途密钥，AEAD 保护消息内容与上下文。身份认证、防重放和生命周期还需协议负责。

12 · RSA：从数论到安全编码

能手算 RSA，才容易看清“裸算法”为什么不够安全。

需要时回查：附录 C

12.1 生成密钥

选不同的大素数 p 、 q ，令 $n=pq$ ， $\varphi(n)=(p-1)(q-1)$ ，也可用 $\lambda(n)=\text{lcm}(p-1, q-1)$ 。选择 e 与 $\lambda(n)$ 互素，计算 $d=e^{-1} \bmod \lambda(n)$ 。公钥 (n, e) ，私钥包含 d 与受保护的素因子。教学上常用 $\varphi(n)$ 求逆，同样满足要求。

12.2 教学变换

$$c=m^e \bmod n; m=c^d \bmod n; 0 \leq m < n$$

如果 $\gcd(m, n)=1$ ， $ed \equiv 1 \bmod \varphi(n)$ 和 Euler 定理给出 $m^{ed} \equiv m$ 。对不互素的 m ，可分别模 p 、 q 分析：若 $m \equiv 0$ ，则幂仍为 0；否则用 Fermat 定理。两个模素数的结论由 CRT 合并，因此正确性覆盖所有合法消息代表。

12.3 完整算例

$p=61$ ， $q=53$ ， $n=3233$ ， $\varphi(n)=3120$ 。取 $e=17$ ，则 $d=2753$ ，因为 $17 \times 2753 = 46801 = 15 \times 3120 + 1$ 。 $m=65$ 时 $c=65^{17} \bmod 3233=2790$ ；再算 $2790^{2753} \bmod 3233$ 得到 65。这些数字很小，攻击者可以瞬间分解 n ，只可用于教学。

12.4 裸 RSA 的失败

它是确定性的，攻击者可把猜测消息直接加密并比较。它还有乘法结构： $\text{Enc}(m_1) \cdot \text{Enc}(m_2) \equiv \text{Enc}(m_1 m_2) \bmod n$ 。在解密预言机场景，把挑战 c 乘 r^e 得到相关密文，其解密结果是 mr ，可用于还原目标消息。正确性并不蕴含 CPA 或 CCA 安全。

12.5 OAEP 与 PSS 的位置

RSA-OAEP 对加密消息进行随机化编码；RSA-PSS 是签名编码。两者用途不同，不能用“私钥加密”这个比喻替代签名定义。具体接口、散列、掩码生成和长度限制见 RFC 8017 [11]。以 k 字节模数和 $hLen$ 字节哈希为例，OAEP 最大消息长度是 $k-2hLen-2$ ；RSA-2048 配 SHA-256 得到 190 字节。因此它通常用于包装短秘密，而不是直接加密大文件。

12.6 CRT 加速与故障

私钥运算可以分别模 p 、 q 做较小的模幂，然后 CRT 合并，提升性能。但单边计算故障可能暴露素因子。在

典型签名故障模型中，错误签名 s' 仅模一个素数正确，则 $\gcd((s')^e - m, n)$ 可能给出非平凡因子。实现需要故障检查等保护。

12.7 假设与实施

知道分解 n 可以计算私钥；但在一般情况下，“求逆 RSA”与“分解”不能随意声称已有等价证明。安全还取决于素数质量、私钥保护、盲化、恒定时间、编码检查和错误行为。用成熟库处理大整数、填充和验证，不自行实现生产 RSA。

练习与参考答案

1. 用 $p=5$ 、 $q=11$ 、 $e=3$ 生成教学 RSA，计算 d ，并加密 $m=7$ 。

参考答案

$n=55$ ， $\phi=40$ ， $d=27$ ，因为 $3 \times 27 \equiv 1 \pmod{40}$ 。 $c=7^3 \pmod{55}=13$ ； $13^{27} \pmod{55}=7$ 。

2. 为何不把原始 RSA 私钥幂运算直接称作安全签名？

参考答案

裸数学关系缺少消息编码、哈希与安全定义，存在可构造的伪造结构。实际签名需标准编码与正确验证，例如 RSA-PSS。

13 · Diffie-Hellman 与认证

共享秘密可以从公开交换中产生，但还要知道自己在和谁共享。

需要时回查：附录 C附录 E

13.1 在有限群中交换

取适当的循环群 G ，阶 q ，生成元 g 。Alice 随机选 $a \in \mathbb{Z}_q$ ，发送 $A = g^a$ ；Bob 选 b ，发送 $B = g^b$ 。双方算 $z = B^a = A^b = g^{ab}$ 。对手看到 g 、 A 、 B ，若 CDH 困难就难以直接计算 z 。 z 还应经过 KDF，不能把群元素的随意截取直接当 AEAD 密钥。

13.2 三个假设

- **DLP**：给定 g 、 g^a ，求 a 。
- **CDH**：给定 g 、 g^a 、 g^b ，求 g^{ab} 。
- **DDH**：给定 g 、 g^a 、 g^b 、 T ，区分 T 是 g^{ab} 还是随机群元素。

能解 DLP 就能解 CDH；能解 CDH 通常可判定对应 DDH 实例。但“DLP 困难”不足以在任何群中推出 DDH 困难；某些带配对的群允许高效判定特定 DDH 问题。

13.3 教学算例

取 $p=23$ 、 $g=2$ ， g 生成阶为 11 的子群。Alice 取 $a=6$ ， $A=2^6 \bmod 23=18$ ；Bob 取 $b=7$ ， $B=2^7 \bmod 23=13$ 。Alice 算 $13^6 \bmod 23=6$ ；Bob 算 $18^7 \bmod 23=6$ 。旁观者知道两个公开值，但真实参数下遍历指数应该不可行。

13.4 中间人攻击

Mallory 拦截 A 、 B ，用自己的公开值分别替换。Alice 与 Mallory 得到一把钥匙，Bob 与 Mallory 得到另一把。Mallory 解密、修改再加密，双方可能都以为在直接通信。这不是破解 DH；DH 本来只提供建立秘密的数学机制。

认证密钥交换必须认证身份与交换值，并绑定完整握手 transcript、角色、协议版本、算法和上下文。只签一个裸公钥、遗漏角色或会话信息，可能仍产生错配或重放问题。密钥确认让一方知道另一方也持有本次会话密钥。

13.5 前向保密

使用临时 a 、 b 并在会话后销毁，可以使后来泄露的长期签名密钥不足以恢复先前会话秘密。前向保密不是“任何泄露都无害”：若会话进行时端点被攻陷、临时密钥被记录或随机数有问题，旧数据仍可能泄露。静态 DH 与临时 DH 的性质不同。

13.6 小子群与输入验证

对手若提供阶很小的群元素，接收方计算后可能泄露私有指数的模小因子信息。需根据所用协议执行成员检查、阶相关处理和异常结果检查。对 X25519 等接口，应遵循规范处理，包括在需要时拒绝全零共享结果；不能把所有曲线的验证要求混成一套。

练习与参考答案

1. 在算例中，验证 Bob 与 Alice 的共享值相同。

参考答案

$18^2 \equiv 2$, $18^4 \equiv 4$; $18^7 \equiv 4 \times 2 \times 18 \equiv 6 \pmod{23}$ 。 $13^2 \equiv 8$, $13^4 \equiv 18$; $13^6 \equiv 18 \times 8 \equiv 6$ 。

2. 只把 DH 公开值发到网络上，是否可以防止中间人？

参考答案

不能。必须用可信密钥、证书或预共享认证机制绑定双方身份与握手上下文，并正确进行密钥确认。

14 · 椭圆曲线密码学

曲线提供的是一个代数群，不是画图越复杂越安全。

需要时回查：附录 C附录 E

14.1 有限域上的曲线

在素域 F_p ($p > 3$) 上考虑 $y^2 = x^3 + ax + b$ ，要求 $4a^3 + 27b^2 \not\equiv 0 \pmod{p}$ ，避免奇异曲线。合法点连同无穷远点 O 组成群。实际曲线还涉及域、曲线阶、基点阶和余因子；只给一个方程不足以定义密码参数。

14.2 点加与倍点

若 $P=(x_1, y_1)$ 、 $Q=(x_2, y_2)$ ，且 $x_1 \neq x_2$ ，则斜率 $s=(y_2 - y_1)/(x_2 - x_1) \pmod{p}$ ，除法表示乘模逆元。倍点且 $y_1 \neq 0$ 时， $s=(3x_1^2 + a)/(2y_1)$ 。然后：

$$\begin{aligned}x_3 &= s^2 - x_1 - x_2 \pmod{p} \\ y_3 &= s(x_1 - x_3) - y_1 \pmod{p}\end{aligned}$$

点的负元为 $(x, -y \pmod{p})$ 。 $P + (-P) = O$ ； O 是单位元。公式在分母为零时需要分情况，不能直接执行逆元运算。

14.3 手算倍点

曲线 $y^2 = x^3 + 2x + 2 \pmod{17}$ 上， $P=(5, 1)$ 合法，因为 $1^2 \equiv 125 + 10 + 2 \equiv 1$ 。倍点斜率 $s=(3 \times 25 + 2) \times 2^{-1} \equiv 77 \times 9 \equiv 13$ 。 $x_3 = 13^2 - 10 \equiv 6$ ； $y_3 = 13(5 - 6) - 1 \equiv 3$ ，所以 $2P=(6, 3)$ 。进一步 $3P=(10, 6)$ 。这个小群可枚举，毫无真实安全性。

14.4 标量乘与 ECDLP

$Q=[d]G$ 表示把 G 相加 d 次，不是分别把坐标乘 d 。双倍加算法在 $O(\log d)$ 次群操作内计算，生产实现还要处理时间泄露。已知 G 、 Q ，求 d 是椭圆曲线离散对数问题。通用经典攻击如 Pollard rho 约需 $\sqrt{q}$ 次操作，因此约 256 位的合适群阶可对应约 128 位通用攻击强度。

14.5 ECDH、ECDSA、EdDSA 的区别

ECDH 是密钥交换；ECDSA 和 EdDSA 是签名。X25519 通常指基于 Montgomery 曲线的密钥交换函数，Ed25519 指 Edwards 曲线上一种 EdDSA 签名实例。名称接近不代表接口、编码或密钥用途可互换。

14.6 曲线选择与实现

不同坐标形式可减少求逆次数，例如射影坐标把许多计算转为乘法，最后再归一化。Montgomery ladder

的规律结构有助于实现抵抗部分侧信道。仍需要成熟的曲线参数、点编码检查、异常点处理和协议相关验证。

易混淆之处：曲线的有限域大小 p 、曲线总点数 $\#E(F_p)$ 、基点阶 q 与余因子 $h = \#E/q$ 是四个不同量。签名中的模 q 运算与点坐标的模 p 运算不能混用。

练习与参考答案

1. 在模 17 的例子中求 $-P$ 。

参考答案

$P=(5,1)$ ，负点是 $(5,16)$ 。 $P+(-P)=O$ ，不能在普通点加公式中硬求零分母的逆元。

2. 为何 256 位 ECC 密钥不能理解为约 2^{256} 的通用攻击成本？

参考答案

对阶约 2^{256} 的群，经典通用离散对数攻击约 2^{128} 次群操作。实际强度还依曲线结构、实现和攻击模型而定。

15 · 数字签名与证书

签名证明消息与一把密钥的关联；身份还需要可信绑定。

需要时回查：附录 C附录 E

15.1 签名接口

$\text{Gen} \rightarrow (\text{pk}, \text{sk})$, $\text{Sign}(\text{sk}, m) \rightarrow \sigma$, $\text{Verify}(\text{pk}, m, \sigma) \rightarrow \text{接受或拒绝}$ 。签名通常不加密消息，任何知道公钥的人都能验证。不可伪造与法律意义的不可否认不同：后者还涉及密钥控制、授权、审计、撤销和制度证据。

15.2 Schnorr 的结构

在阶 q 的循环群中，私钥 x ，公钥 $Y = g^x$ 。签名选择新鲜随机 r ，计算 $R = g^r$ 、 $e = H(\text{domain} \parallel \text{Encode}(R, Y, m)) \bmod q$, $s = r + ex \bmod q$ 。验证 $g^s = R \cdot Y^e$ 。正确性来自 $g^{r+ex} = g^r (g^x)^e$ ；安全需要离散对数相关假设与合适的哈希模型和编码。

教学算例： $p=23$ 、 $q=11$ 、 $g=2$ 、 $x=3$ ， $Y=8$ 。取 $r=4$ ， $R=16$ ；为手算假设挑战 $e=5$ ，则 $s=4+15 \equiv 8 \bmod 11$ 。 $g^s=3$ ， $R \cdot Y^e=16 \times 8^5 \equiv 3 \bmod 23$ 。这里 e 是教学给定值，实际必须由规范化哈希计算。

15.3 随机数重用会泄露私钥

$$\begin{aligned} s_1 &= r + e_1 x; s_2 = r + e_2 x \\ x &= (s_1 - s_2)(e_1 - e_2)^{-1} \bmod q \end{aligned}$$

前提是 $e_1 \neq e_2$ 、可求逆。若上述例子第二次 $e_2=2$ ，则 $s_2=10$ ， $(8-10)/(5-2) \equiv 9 \times 4 \equiv 3$ ，即恢复 x 。ECDSA 也有类似危险，偏置或部分泄露都可能损伤安全。确定性 nonce 构造可以减少对运行时随机源的依赖，但要遵循专门标准，仍需抗侧信道。

15.4 ECDSA 的基本公式

私钥 d ， $Q = dG$ ；取 $k \neq 0$ ， $R = kG$ ； $r = x(R) \bmod q$ ； $s = k^{-1}(H(m) + rd) \bmod q$ ，并按规范处理零值。验证计算 $w = s^{-1}$ ， $u_1 = H(m)w$ 、 $u_2 = rw$ ，检查 $x(u_1G + u_2Q) \bmod q$ 是否等于 r 。实际涉及哈希截断、范围检查、编码与可延展性。看懂公式不等于写出了安全库。

15.5 EdDSA

EdDSA 利用特定哈希派生机制生成每条消息的 nonce 与挑战。Ed25519 等实例的编码、验证条件、上下文和预哈希变体见 RFC 8032 [7]。不要自行把“先哈希”当作所有签名 API 的等价输入方式；普通模式与预哈希模式可能有不同域分离。

15.6 PKI 与证书链

证书把身份信息、公钥、用途和有效期等绑定在颁发者签名下。客户端验证链到可信根，检查名称、时间、用途、算法和必要的状态信息。仅仅“证书签名有效”不足以证明它适用于当前主机名。信任根被攻陷或证书错误签发属于系统层风险。

15.7 签什么内容

审批签名应绑定业务对象、版本、金额、币种、接收人、用途和期限，明确字符编码与字段边界。例如只签金额而不签收款账户，签名仍可被搬到别的付款指令。签名不能判断内容是否真实：一个合法密钥持有者可以签署错误或欺骗性的陈述。

练习与参考答案

1. Schnorr 随机数 r 重用，为什么两条签名能恢复 x ？

参考答案

两式相减消掉 r ，得到 $s_1 - s_2 = (e_1 - e_2)x$ 。阶 q 为素数且挑战不同，差值可逆，所以可求 x 。

2. 验证通过是否说明文档里的事实真实？

参考答案

只说明这些字节与对应签名密钥有关，且满足算法验证条件；事实真实性、签署权限和密钥是否被盗还需另外判断。

16 · TLS、端到端加密与协议组合

安全通信需要密钥交换、认证、派生和状态共同配合。

16.1 为什么不能只说“HTTPS 用 RSA”

现代 TLS 是一套协议，不是一个算法。它协商参数，认证对端，建立会话秘密，派生方向不同的流量密钥，再以 AEAD 保护应用数据。TLS 1.3 的教学流程可以参考 RFC 8446 [4]；这里只描述典型证书认证、临时密钥交换的主干，实际还有 PSK、会话恢复等分支。该参考不是对所有后续更新状态的断言，部署时查 RFC 状态页与勘误。

16.2 典型握手的职责

逻辑阶段	交换内容	解决的问题
客户端提出参数	版本、算法、临时公开值等	表达可支持能力
服务器选择并响应	选定参数、临时公开值	双方建立共同协议上下文
服务器认证	证书与握手签名	将身份、密钥与本次握手绑定
Finished 等确认	对握手记录的认证	验证本次密钥与记录一致
应用数据	序号相关 nonce 与 AEAD 记录	保护内容并管理记录状态

验证者必须检查服务名称与信任链，而非仅检查签名数学关系。握手密钥和应用密钥用途分离，上传与下载方向分离；协议记录参与认证，防止把合法碎片拼成另一次握手。

16.3 0-RTT 的代价

提前发送数据可减少等待，却存在重放方面的特殊风险。即使提前数据能被正确解密和认证，也不代表它只被处理一次。转账、下单等有副作用操作需要明确的抗重放与幂等机制，或不用提前数据执行。

16.4 TLS 与端到端加密

TLS 通常保护客户端到服务器的传输；服务器作为端点可看到业务明文。端到端加密把解密能力限制到最终用户设备，使中转服务不必持有内容密钥。但设备备份、同步、成员变更、举报、恢复和密钥验证会重新引入复杂的信任安排。

16.5 Ratchet 的直觉

密钥棘轮持续更新密钥，擦除旧密钥以缩小泄露影响。对称棘轮根据单向派生推进；DH 棘轮通过新交换重新注入秘密。前向保密关注泄露后的历史保护；攻陷后安全关注对手退出后能否恢复未来秘密。后者需要新的未泄露材料，不能只反复哈希已被知道的当前密钥。

16.6 协议组合的常见错误

- 只认证交换值、不认证角色：可能把客户端消息反射到服务端接口。
- 未绑定版本与算法：可能存在降级或跨协议混用。
- 把认证失败的明文先提交业务：后续拒绝也无法撤销副作用。
- 序号在重启后回零：可能重放，也可能重复 AEAD nonce。
- 多台节点共用密钥却独立从零计数：唯一性在全局不成立。

16.7 形式化分析与现实

符号模型把加密抽象成理想操作，适合查协议逻辑；计算模型进一步考虑概率和困难性；实现测试检查解析、状态和边界。形式化工具证明的是所输入的模型，遗漏的业务行为、实现分支和随机源仍需单独检查。

练习与参考答案

1. HTTPS 网站是否意味着服务运营者无法读取上传内容？

参考答案

不意味着。TLS 的服务器端通常持有解密能力。要让中转服务无法读取，需要设计端到端加密及其密钥、恢复与设备信任机制。

2. 攻击者已得到棘轮当前密钥，只做 $K' = H(K)$ 能恢复未来秘密吗？

参考答案

不能，对手同样可算 $H(K)$ 。恢复未来秘密需要注入新的、对手不知道的材料，且对手已退出受控设备。

17 · 密钥管理与密码生命周期

算法可以换，泄露或丢失的主密钥会影响整套系统。

17.1 生命周期

生成 → 分配与导入 → 存储 → 使用 → 轮换 → 撤销或归档 → 销毁。每一步都要回答谁能访问、在哪里发生明文操作、有没有审计、如何恢复。密钥管理不是仅把字符串从代码移到环境变量。

17.2 信封加密

为文件或数据对象生成数据密钥 DEK，用 AEAD 加密内容。再用密钥加密密钥 KEK 包装 DEK；KEK 由 KMS/HSM 等受控服务保护。记录包含密文、nonce、标签、被包装 DEK、key ID、版本和上下文。轮换 KEK 时可能仅重包装 DEK，无须重加密所有大文件；若 DEK 已泄露，重包装不能收回攻击者已知的明文能力。

17.3 KMS、HSM 与权限

HSM 可限制秘密材料导出并执行受控运算；KMS 提供密钥管理接口与策略。应用若拥有随意解密所有记录的权限，即使密钥不可导出也可能被攻陷后批量调用解密。最小权限、调用上下文、审计与速率控制同样重要。硬件边界不能代替业务授权。

17.4 轮换、撤销与重新加密

轮换指开始使用新密钥；撤销指禁止某些旧用途；重新加密指用新材料更新已存数据。这三件事不能互相替代。旧数据若仍需要读取，可能保留旧解密密钥或进行迁移。签名公钥还可能需长期保留，以验证历史证据；删除私钥不应删除所有可验证历史的材料。

17.5 备份与销毁

没有恢复方案可能因设备损坏永久丢数据；恢复渠道过宽又可能成为绕过主防线的入口。密钥删除只有在所有副本、缓存、备份和包裹关系得到处理后，才可能支持密码学擦除目标。普通内存中的字符串还可能被复制、交换到磁盘或记录在崩溃转储中。

17.6 多用户与多用途

避免全公司共用一个不可区分用途的主密钥。应明确租户边界、对象级子密钥和用途标签；但密钥数量增加也提高管理成本。撤销员工权限，应撤销其调用能力与会话，而不只是更换登录密码。已经下载的明文无法通过远程轮换自动收回。

17.7 密码敏捷性

系统应能够迁移算法、参数、库版本与密钥格式。格式里记录版本与明确算法标识，但不能让客户端无限制选择任意算法。迁移需要资产清单、兼容测试、回滚设计和旧数据处理，不是单纯添加一个新下拉框。

练习与参考答案

1. KEK 轮换后，曾泄露的 DEK 是否恢复安全？

参考答案

不会。攻击者已持有 DEK，就可能继续解开其可获得的对应密文；需要按泄露范围更换 DEK、重新加密并处理访问与副本。

2. 密钥不允许导出，应用被攻陷还可能泄露什么？

参考答案

应用可利用被授权的解密或签名接口，读取明文、批量解密或签伪造业务。不可导出保护材料本体，不自动限制所有滥用。

18 · 侧信道、故障与实现验证

安全证明之外的可观察行为，也能成为秘密的出口。

18.1 侧信道是什么

攻击者通过运行时间、缓存、功耗、电磁辐射、错误信息或流量长度推断秘密。数学模型可能只允许看到密文，实现却让对手多看到一个变量。侧信道不是“密码学不管的偶然小问题”，而是实现安全的核心研究对象。

18.2 计时和缓存

私钥比特决定是否执行乘法，或秘密字节决定查哪个表项，都会使执行轨迹与秘密相关。恒定时间通常要求控制流和内存访问不依赖秘密，且避免相关可变时延指令。源代码写了无分支不代表编译后一定符合条件；语言运行时和硬件也影响结果。

“恒定时间”不要求所有不同长度输入耗时完全相同；公开长度可以影响工作量。关键是明确哪些信息被允许公开、哪些不能通过时序泄露。随机加延时通常不能根本解决问题，攻击者可多次采样消除噪声。

18.3 功耗、掩码与盲化

设备功耗可能与中间值的位数或变化相关，统计分析可聚合大量执行。掩码把秘密中间值拆成多个随机份额，盲化随机化数学运算输入或过程；都需要正确的随机性与专门分析。一个反制可能阻止一阶泄露，却仍遭高阶联合分析。

18.4 故障攻击

对手用电压、时钟或激光扰动计算，让签名错误、跳过验证或产生可分析的偏差。RSA-CRT 是典型教学例子。保护可能包括冗余计算、结果校验与故障响应，但要分析对手能否同时破坏检查路径。

18.5 流量与压缩泄露

即使内容加密，长度、方向、时刻和访问频率仍可能暴露行为。如果秘密与攻击者可控输入共同压缩，再暴露压缩后长度，攻击者可能通过重复猜测推断秘密。防范要改变数据混合与压缩策略；把密钥从 128 位换到 256 位不能修复长度预言机。

18.6 验证的层次

检查	能发现什么	不能独自证明什么
标准测试向量	已知输入输出、编码错误	所有输入正确、安全性
负向与边界测试	篡改、异常点、标签错误、长度边界	没有未知逻辑漏洞
状态测试	重启、并发、回滚、重复 nonce	密码困难性

模糊测试	解析崩溃、异常分支	完整密码安全证明
侧信道评估	秘密相关时序或统计泄露	所有环境无泄露
形式化验证与审查	明确模型中的性质	模型以外的行为

18.7 工程中的成熟默认值

使用维护中的高层密码接口；限定算法集合；先认证再使用明文；严格解析；分离用途密钥；记录公开的审计元数据而非秘密；针对实际运行环境验证。不要把教学模幂、曲线点加或 toy LWE 代码放进业务系统。

练习与参考答案

1. 让签名接口随机多睡 0—100 ms 能消除私钥相关计时吗？

参考答案

通常不能。反复采样可降低独立噪声，秘密相关偏差仍可能保留；应改用经过分析的恒定时间实现与相关反制。

2. 标准测试向量都通过，可以宣布实现绝对安全吗？

参考答案

不能。它主要检查部分正确性与编码，还需负向、状态、解析、侧信道、依赖版本和运维验证。

19 · 实验室：从手算到库调用

实验要观察正常输出，也要观察篡改、错配和错误失败。

19.1 学习环境

纸笔实验不需要工具；交互台在 HTML 版本中运行。下面的 Python 示例需要 Python 3 与 cryptography 包，可在隔离的虚拟环境安装。示例只处理自建测试数据，不访问外部服务。它展示接口语义，不包含生产系统所需的密钥持久化、nonce 分配与权限管理。

```
python -m venv .venv
# macOS / Linux : source .venv/bin/activate
# Windows PowerShell : .venv\Scripts\Activate.ps1
python -m pip install cryptography
```

19.2 AES-GCM：三个失败用例

高层 AEAD API 参考 [cryptography 官方文档 \[12\]](#)。这段代码每次运行生成新密钥，只加密一条消息，避免把随机 nonce 示例误当无限次使用策略。

```
import os
from cryptography.hazmat.primitives.ciphers.aead import AESGCM
from cryptography.exceptions import InvalidTag

key = AESGCM.generate_key(bit_length=256)
aead = AESGCM(key)
nonce = os.urandom(12)
aad = b"demo-v1|tenant-7|object-9|version-1"
plaintext = "仅用于学习的消息".encode("utf-8")
ct = aead.encrypt(nonce, plaintext, aad) # 输出已包含标签
assert aead.decrypt(nonce, ct, aad) == plaintext

changed = bytes([ct[0] ^ 1]) + ct[1:]
wrong_nonce = bytes([nonce[0] ^ 1]) + nonce[1:]
cases = [(nonce, changed, aad),
         (nonce, ct, aad + b"!"),
         (wrong_nonce, ct, aad)]
for n, c, a in cases:
    try:
        aead.decrypt(n, c, a)
    except InvalidTag:
        print("拒绝：认证失败")
    else:
        raise AssertionError("篡改未被拒绝")
```

预期输出三次“拒绝：认证失败”。实验说明此测试实现拒绝了这三类修改，不构成算法安全证明。不可把 key 输出到日志。实际跨进程与多节点使用时，单独设计 nonce 管理。

19.3 HMAC 与域分离

```
import hmac, hashlib, secrets
key = secrets.token_bytes(32)
message = b"approval-v1\x00invoice-123\x00JPY\x00100000"
tag = hmac.digest(key, message, "sha256")
assert hmac.compare_digest(tag, hmac.digest(key, message, "sha256"))
bad = message.replace(b"100000", b"900000")
assert not hmac.compare_digest(tag, hmac.digest(key, bad, "sha256"))
```

这里只用受控固定字段展示。若任意用户字段能包含分隔符，必须换成长度前缀或规范编码，防止拼接歧义。不要把“加了分隔符”当成对所有数据都无歧义。

19.4 小参数实验任务

1. 用快速模幂复现 RSA 算例，然后修改 m ，观察每次是否正确恢复。
2. 用 $p=23$ 的 DH 参数枚举全部 11 个指数，恢复公开值的私有指数，体会小参数的不安全。
3. 使用同一个 XOR 掩码加密两条消息，验证密文异或等于明文异或。
4. 在小输出空间里采样“哈希值”，记录首次碰撞的样本数，观察并非必须到空间大小才碰撞。

19.5 本地交互台

以下为 HTML 交互台对应的静态示例；模幂、模逆元和 XOR 是教学运算，不具备生产侧信道保护。生日估计使用浮点近似。实时输入计算请使用 HTML 版本。

模幂 $a^e \bmod n$

算例： $65^{17} \bmod 3233 = 2790$ 。交互计算功能请使用 HTML 版本。

模逆元 $a^{-1} \bmod n$

算例： $17^{-1} \bmod 3120 = 2753$ 。交互计算功能请使用 HTML 版本。

等长十六进制 XOR

算例： $b4 \oplus 6d = d9$ 。交互计算功能请使用 HTML 版本。

生日碰撞估计

算例：96 位空间均匀独立采样 10^6 次，碰撞概率约 6.31×10^{-18} 。交互计算功能请使用 HTML 版本。

19.6 实验报告模板

记录假设、输入类型、算法与库版本、预期行为、真实输出、失败用例和未覆盖风险。报告中放公开测试向量，不放真实业务密钥或敏感明文。能够解释失败用例为何被拒绝，比只展示“加密成功”更有学习价值。

练习与参考答案

1. 把真实生产私钥输入教学交互台是否有必要？

参考答案

没有。用小参数就能观察数学机制；教学页面不承担密钥存储、侧信道或专业运行环境保证。

2. AEAD 三个负向用例之外，下一步该测试什么？

参考答案

测试错误密钥、截断与空输入、重放行为、分块重排与缺失、重启和并发 nonce 分配。根据系统设计挑选有意义的状态与边界测试。

20 · 承诺、零知识与知识证明

证明“我知道”，不等于把秘密交出去。

需要时回查：附录 E附录 H

20.1 承诺：先固定，后公开

承诺像把答案封进信封：提交时别人看不到，打开时不能换答案。 $\text{Commit}(m;r) \rightarrow c$ ， Open 给出 m 和随机性 r 。隐藏性阻止推断 m ；绑定性阻止给同一个 c 找到两个不同的有效打开。仅 $H(m)$ 对低熵 m 可能不隐藏；需要随机化和明确的安全假设。

20.2 Pedersen 承诺

$C = g^m h^r$ ，在素数阶 q 的群中， $r \leftarrow \mathbb{Z}_q$

若 h 是生成元且 r 均匀，固定 m 时 h^r 遍历整个群，因此 C 分布不依赖 m ，具有完美隐藏。若攻击者给出 $g^m h^r = g^{m'} h^{r'}$ 且 $m \neq m'$ ，可推导 $g^{m-m'} = h^{r'-r}$ ，求出 g 、 h 之间的离散对数关系。绑定性依赖这一关系对攻击者未知。参数生成者若知道 $h = g^a$ 的 a ，就可能拥有陷门。

20.3 零知识的三项性质

- 完备性：真实陈述与诚实证明者应让验证者接受。
- 可靠性：虚假陈述不应被有效证明者轻易接受。
- 零知识：验证者看到的执行记录可在不拥有秘密见证时模拟。

知识证明还要求存在一个提取器：若证明者能以足够概率让验证者接受，则可在定义允许的方式下提取见证。这比“陈述是真的”更强。模拟与提取都是形式化定义中的算法，不是生产系统偷偷读取用户秘密。

20.4 Schnorr 身份知识证明

公开 $Y = g^x$ ，证明者知道 x 。先选 r ，发送 $R = g^r$ ；验证者随机给挑战 e ；证明者发 $s = r + ex \bmod q$ ；验证 $g^s = RY^e$ 。它是 Σ 协议的代表。

特殊可靠性：同一 R 下两组不同挑战的有效回答可提取 $x = (s - s') / (e - e')$ 。诚实验证者零知识：模拟器先选随机 e 、 s ，再设 $R = g^s Y^{-e}$ ，得到与真实执行相同的记录分布。由于模拟器提前选了挑战，这说明的是诚实验证者零知识；对任意恶意验证者需要更完整的论证或协议改造。

20.5 Fiat-Shamir 变换

把验证者随机挑战换成 $e = H(\text{domain}, \text{statement}, R, \text{context})$ ，可把某些交互证明变为非交互形式，也通向 Schnorr 类签名。安全常在随机预言机等模型下分析，不能对所有交互协议机械套用。陈述、公钥、协议

上下文与用途标签都应绑定。

20.6 SNARK、STARK 与可信设置

SNARK 追求简短、可快速验证的非交互论证；不同家族可能依赖特定设置、通用设置或透明设置。STARK 常采用哈希相关结构与可扩展的代数检查，但证明大小和性能有自身成本。并非所有名为 SNARK 的系统都自动具有零知识，需要检查具体方案与配置。

20.7 现实应用的界限

可证明“余额非负”“知道口令对应的秘密”“计算遵循某程序”，但如果输入数据本身是假，正确执行也可能输出误导结果。程序电路遗漏约束，会证明一个比预想更弱的命题。零知识不是内容真实性、输入质量或授权的替代品。

练习与参考答案

1. 为何 Pedersen 需要参数之间的离散对数关系未知？

参考答案

若知道 $h=g^\alpha$ ，可调整 m 、 r 保持 $m+\alpha r$ 不变，制造不同打开，破坏绑定性。

2. 能模拟证明记录，为什么不等于攻击者能随意冒充？

参考答案

模拟器可预选挑战或使用定义中的特殊能力；真实交互攻击者在发送承诺后必须应对未知挑战。顺序与访问能力不同。

21 · 秘密分享、安全计算与同态加密

多个参与者可以协作使用秘密，而不必先集中公开。

需要时回查：附录 E附录 G

21.1 加法分享

在 F_q 中，把秘密 s 分成随机 a 与 $b=s-a$ 。单独一份均匀，看不出 s ；两份相加恢复。分享可以扩展到多个参与者。线性运算容易本地执行：分享相加、乘公开常数仍是对应结果的分享。秘密相乘则需要交互或预处理。

21.2 Shamir 门限分享

选有限域，取随机次数至多 $t-1$ 的多项式 $f(x)=s+a_1x+\dots+a_{t-1}x^{t-1}$ ，秘密为 $f(0)$ 。给不同、非零 x_i 的参与者份额 $(x_i, f(x_i))$ 。任意 t 份可插值恢复；不足 t 份时，所有秘密值与观察结果同样兼容，获得完美隐私。要求系数均匀且字段与 x 选择正确。

2-of-3：在 F_{17} 上， $s=5$ ， $f(x)=5+3x$ 。三份为 $(1,8)$ 、 $(2,11)$ 、 $(3,14)$ 。用前两份， $f(0)=8\cdot 2/(2-1)+11\cdot 1/(1-2)=16-11=5 \bmod 17$ 。

秘密分享本身不检测恶意份额。可验证秘密分享、认证和纠错增加相应保护；门限恢复也不等于门限签名，后者要求在不重建完整私钥的情况下共同产生签名。

21.3 MPC 的理想目标

安全多方计算让参与者得到 $f(x_1, \dots, x_n)$ ，只泄露输出与明确允许的信息。理想功能像一个受信任箱子，真实协议应在定义中模拟这个箱子。需要说清诚实但好奇还是恶意、可腐化人数、串谋、网络模型、中止与公平性。

21.4 乘法为什么难

两份秘密 a 、 b 的本地份额相乘会漏掉交叉项。Beaver 三元组提前分享 u 、 v 、 $w=uv$ 。在线阶段打开 $d=a-u$ 、 $e=b-v$ ，计算：

$$ab=w+dv+eu+de$$

这里打开的是由随机 u 、 v 掩盖的差值。三元组要正确、独立且一次使用，并按参与者规则分配公开项 de 。三元组重用会暴露秘密差异；恶意安全还要检查份额和预处理。

21.5 不经意传输与混淆电路

1-out-of-2 OT 让接收者取到发送者两个消息之一，发送者不知道选择，接收者得不到另一个。混淆电路把每根线的 0/1 表示为随机标签，并加密门表；OT 帮助获取正确输入标签。真实安全来自严密构造与模型，不是把真值表简单加密就完成。

21.6 同态加密

同态加密允许在密文上执行与明文运算对应的操作。部分同态支持一种运算，分层同态支持有限深度，全同态可支持更一般计算，常用 bootstrapping 刷新噪声。噪声是结构的一部分，积累过大影响解密；性能、参数与数值编码是核心约束。

同态加密不自动保证计算方诚实执行，也不隐藏所有输出信息。CKKS 等近似算术方案存在数值误差，不能把其结果当精确整数。可验证计算、MPC、差分隐私与同态加密解决的问题不同，有时可互补。

练习与参考答案

1. Shamir 的 $x=0$ 份额为什么不能随便分发？

参考答案

因为 $f(0)=s$ ，直接暴露秘密。份额位置必须不同且非零。

2. MPC 只泄露输出，是否意味着不会泄露敏感信息？

参考答案

输出本身可能泄露。例如两个用户的平均值与自己的输入可恢复另一人的值。必须限制查询与输出，必要时采用额外隐私设计。

22 · 后量子密码与格基础

抗量子算法运行在普通计算机上，不需要量子网络。

需要时回查：附录 E附录 G附录 H

22.1 量子威胁分成两类

Shor 算法在足够大且可靠的量子计算机上可高效处理整数分解和相关离散对数问题，威胁 RSA、有限域 DH 与常见 ECC。Grover 算法提供无结构搜索的平方级查询加速，影响对称穷举的理想复杂度；它不是对任何密码问题都提供指数加速，实际成本还受容错、深度与并行性影响。

“先收集，后解密”指今天录下使用易受量子攻击公钥机制保护的通信，未来再恢复秘密。是否急需迁移与数据保密寿命、系统替换周期和攻击价值有关，不需要假装知道大型量子计算机的确切到来年份。

22.2 格与 LWE 的直觉

格是整数线性组合形成的离散点集，二维中 $L = \{z_1b_1 + z_2b_2 \mid z_i \in \mathbb{Z}\}$ 。高维下某些短向量或近点问题困难。LWE 给出模 q 的带噪线性方程：

$$b = A \cdot s + e \pmod q$$

A 是公开随机矩阵， s 是秘密向量， e 是小随机噪声。无噪声时常可用线性代数解；适当参数与分布下，噪声使恢复或区分更困难。“加了噪声”不是自动安全，维度、模数、噪声大小、样本数与结构共同决定风险。

22.3 一个标量教学模型

为看懂消去而非模拟安全，取 $q=17$ 、 $s=3$ 、公开 $a=5$ 、 $e=1$ ，则 $b=as+e=16$ 。加密位 m ，用随机小 r 和误差 e_1 、 e_2 ： $u=ar+e_1$ ， $v=br+e_2+[q/2]m$ 。接收者算 $v-su=er+e_2-se_1+8m$ 。若噪声足够小，可判它更接近 0 还是 8，恢复位。 $q=17$ 、标量秘密可直接枚举，毫无密码安全；真实方案用高维、专门分布、压缩和 CCA 转换。

22.4 标准化的三种角色

标准	名称	用途	主要路线
FIPS 203 [8]	ML-KEM	共享秘密封装	模块格 / Module-LWE
FIPS 204 [9]	ML-DSA	数字签名	模块格
FIPS 205 [13]	SLH-DSA	无状态哈希签名	哈希树结构

三项标准于 2024 年发布。名称中的数字或参数级别不能当作 AES 密钥位数直接比较。标准化表示经过系统评估并形成规范，不是数学上已经证明任何量子攻击都不可能。实现前应查看官方勘误与平台支持。

22.5 后量子体系不止格

还有基于纠错码的路线、哈希签名等。某个家族出现方案被破，并不自动证明全部后量子密码失败；同样，某个参数集被标准化，也不能为任意缩小参数的“轻量版”背书。哈希签名的有状态版本必须可靠管理一次性密钥使用状态，回滚与并发可能致命。

22.6 混合迁移

把传统共享秘密与后量子共享秘密按经过分析的 combiner/KDF 合并，可减少对单一路线的依赖。安全不是把两个密钥字节随便拼接：需要绑定算法、角色、公开值、失败处理和协商记录。混合握手的长度、延迟、证书链和老设备兼容性都要测试。

22.7 迁移的实际清单

盘点 TLS、VPN、证书、代码签名、设备固件、数据库密钥包装、备份和长期归档；区分密钥建立与签名；确定保密期限和验证寿命；选择规范化协议与审查实现；检查包大小和资源；规划更新与撤销。仅把一处 RSA 改成 ML-KEM 不会完成全系统迁移。

练习与参考答案

1. 后量子密码与量子密钥分发是否一回事？

参考答案

不是。前者是普通计算机上设计为抗量子攻击的数学算法；后者利用量子信道与物理测量建立秘密。

2. 为什么噪声不能越大越好？

参考答案

噪声过小可能削弱困难性，过大会使合法解密失败并损害性能。正确性、安全性与资源必须共同满足参数要求。

23 · 量子密钥分发与 BB84

量子测量提供新的资源，也带来设备与有限样本的约束。

需要时回查：附录 D附录 F附录 I

23.1 BB84 用两种基编码

Z 基为 $|0\rangle$ 、 $|1\rangle$ ；X 基为 $|+\rangle=(|0\rangle+|1\rangle)/\sqrt{2}$ 、 $|-\rangle=(|0\rangle-|1\rangle)/\sqrt{2}$ 。Alice 随机选比特和基，发送对应量子态；Bob 随机选基测量。同基理想测量得到原比特，异基测量得到各半随机结果。见 Bennett-Brassard 原始论文 [14]。

23.2 从量子态到最终密钥

1. 量子传输与测量，得到原始数据。
2. 通过已认证的经典信道交换基信息，保留同基位置，称筛选。
3. 抽样估计错误与潜在信息泄露，决定继续还是中止。
4. 信息协调修正双方不一致，计入公开纠错信息泄露。
5. 隐私放大把较长且部分泄露的串压缩成较短秘密。
6. 确认最终密钥一致，并正确管理认证与后续用途。

23.3 截获重发为什么造成 25% 错误

在理想的全量截获重发模型中，Eve 随机选基测量再发送。考虑最终保留的 Alice-Bob 同基位置：Eve 有 $1/2$ 概率选错基；错基后 Bob 有 $1/2$ 概率得到错比特，所以误码率是 $1/2 \times 1/2 = 1/4$ 。这是一个特定简单攻击的算例，不是所有攻击的完整安全证明，也不是通用中止阈值。

23.4 不可克隆与安全证明

未知量子态不能被统一地完美复制，非正交态也不能被单次测量完美区分；这些性质解释量子信息约束。完整 QKD 安全还要处理任意允许攻击、纠错泄露、有限样本和设备假设。Shor-Preskill 给出 BB84 重要安全证明路径，见 原论文 [15]。

23.5 经典认证为什么仍必需

若经典交流不认证，中间人可以分别扮演两端，建立两条独立链路。QKD 不会凭空解决身份绑定。初始认证可来自预共享秘密或相应认证机制，后续某些生成密钥可用于刷新认证材料，但要计入消耗与组合条件。

23.6 现实设备与边界

实际光源可能发送多个光子，探测器有缺陷，线路有损耗，设备可能受侧信道攻击。诱骗态方法等技术用于特定设备问题；测量设备无关协议调整信任假设，但也有自己的条件。没有一个“用了光子”标签就自动保证

端点、密钥存储与认证安全。

23.7 QKD、PQC 和量子计算

概念	运行资源	主要目标	不自动保证
PQC	普通计算与通信	抵抗已知量子攻击的数学方案	信息论安全、端点安全
QKD	量子信道、经典认证信道	在物理与协议假设下建立秘密	数字签名、认证自举、设备无缺陷
量子计算	量子处理器与控制系统	执行量子算法	任意计算加速或无限算力

练习与参考答案

1. 25% 的截获重发误码率是否意味着低于 25% 就必定安全？

参考答案

不是。它只描述理想条件下的某一种攻击。安全密钥率与中止标准来自具体安全证明、设备模型、误码估计和有限样本，而非直接套 25%。

2. QKD 为什么还要经典认证？

参考答案

否则攻击者可替代双方身份，分别建立密钥。量子信道的性质不自动把接收者身份绑定到预期对象。

24 · 综合设计、误区与进阶路线

把所有工具放回一个可以审查的系统中。

24.1 结业任务：企业内部文档系统

需求：多租户存储机密文档，授权员工可读取；存储管理员不能直接看到内容；记录版本可审计；员工离职后停止未来访问。先写威胁模型：若应用服务器解密明文，它属于信任边界；如果要求服务器也不可读，就必须换成端到端设计并重做检索、恢复和协作方案。

24.2 一个可审查的设计骨架

- 1. 内容保护：每对象生成 DEK，使用标准 AEAD；nonce 管理在该 DEK 下唯一。大文件分块绑定块序号、总长度与终止条件。
- 2. 密钥包装：用 KMS 受控 KEK 包装 DEK，key ID 与版本保存在记录中。
- 3. 上下文：AAD 绑定租户、对象、字段类型、格式与版本，使用规范化编码。
- 4. 权限：应用在请求 KMS 前检查租户与对象权限，KMS 策略限制调用用途。
- 5. 版本真实性：对需要独立验证的审计记录使用签名，并保护签名密钥；仅 AEAD 不能向第三方区分是谁写入。
- 6. 防回滚：用可信版本状态或日志承诺判断当前版本；旧的合法密文重放仍可能通过 AEAD。
- 7. 离职撤权：撤销会话、权限与密钥访问；承认已下载明文不能被密码学远程收回。
- 8. 恢复与轮换：测试密钥备份、KEK 重包装、DEK 泄露后的重加密路径。

24.3 设计说明模板

至少包含资产、参与者、信任边界、对手能力、算法与版本、数据格式、nonce 策略、密钥来源、认证上下文、重放状态、错误处理、轮换恢复、验证证据与残余泄露。写清哪些性质来自算法，哪些来自协议状态，哪些来自运维控制。

24.4 常见误区速查

说法	修正
哈希就是不可逆加密	哈希没有合法解密接口，也不能保护低熵输入不被猜测
加密后就不能篡改	需认证；很多保密模式可被定向修改
公钥加密证明发送者	任何人都可用公钥加密，需另行认证
签名通过说明内容真实	证明密钥关联与字节一致，不证明事实正确
nonce 必须秘密	通常公开，重要的是满足算法的唯一性等条件

密钥越长系统一定越安全	泄露、重用、权限与协议缺陷可能主导风险
安全证明覆盖所有现实风险	只在声明的模型与假设中成立
PQC 必须使用量子硬件	PQC 通常在普通硬件上运行
QKD 不需要信任与认证	仍有设备、经典认证与端点假设

24.5 分方向继续学习

- 理论：完整学习安全归约、混合论证、模拟范式、标准模型与随机预言机差异。
- 应用：深入 AEAD、认证密钥交换、PKI、密钥管理与实现分析。
- 隐私计算：先熟悉承诺、OT、秘密分享，再读 MPC 与零知识系统。
- 后量子：加强线性代数、概率、格和多项式环，再读标准及实现研究。
- 量子信息：学习复向量空间、密度矩阵、量子信道、纠错与有限密钥安全分析。

24.6 进阶主题地图

本文没有展开全部细节的领域还包括可搜索加密与泄露函数、匿名凭据、盲签名、群签名、门限签名、双线性配对、基于身份与属性的加密、密码货币协议、可验证随机函数、可验证延迟函数、ORAM 与通用可组合安全。它们不是换一种 AES 模式；先掌握本书核心，再选择与任务有关的分支。Boneh-Shoup 的免费教材可作为系统深化入口，见 [作者页面 \[16\]](#)。

练习与参考答案

1. 存储管理员不能看文件，应用服务器能解密，这是否已经端到端加密？

参考答案

通常不是用户到用户的端到端加密。它实现的是特定信任边界下的存储保密；应用服务器仍是可读明文的受信任端点。

2. 旧版文档 AEAD 标签有效，怎样发现被回滚？

参考答案

标签只说明该记录由允许密钥产生且未被改。需要可信的最新版本状态、审计日志或其他防回滚机制，并将版本纳入上下文。

学习复盘 · 术语表与自测

用独立回答检验理解，不靠重新阅读带来的熟悉感。

核心术语中英对照

术语	英文	最短准确解释
原语	Primitive	具有明确接口的基本密码工具
选择明文攻击	CPA	对手可请求所选消息的加密
选择密文攻击	CCA	对手可在游戏限制下查询解密
预言机	Oracle	可按规定调用的接口，不必是现实网络服务
不可区分	Indistinguishability	观察者不能有效判断来自哪种分布
认证标签	Authentication tag	供接收方验证消息与上下文的短值
关联数据	AAD	认证但不加密的上下文
密钥派生函数	KDF	从输入秘密材料派生用途密钥
密钥封装	KEM	建立短共享秘密而非直接加密任意明文
前向保密	Forward secrecy	一定条件下长期密钥后泄露不破坏旧会话
见证	Witness	证明某陈述的秘密或辅助信息
模拟器	Simulator	在定义中生成可比视图的算法
门限	Threshold	至少一定数量参与者才能完成操作
可信设置	Trusted setup	参数生成需要额外信任或秘密销毁条件
密码敏捷性	Crypto agility	有计划地更新算法、参数和格式的能力

自测方式

下列题目属于本教材练习，建议先遮住答案独立作答，再对照解释。全部答对不意味着已掌握全部推导；还应重做纸笔练习与结业设计。

1. 为什么普通对称加密的 **CPA** 挑战要求两条消息等长？

A. 为了排除长度这个显然的区分器；B. 为了让加密可以解密；C. 为了防止密钥重复

答案：A。普通保密游戏允许长度泄露；隐藏长度需要额外设计。

2. **CTR** 每个密钥下最重要的输入要求？

A. 计数块不能重复；B. 明文必须整块；C. nonce 必须秘密

答案：A。重复计数块重用密钥流，暴露明文关系。

3. 哪一个目标由普通 **AEAD** 自动提供？

A. 防止旧密文重放；B. 隐藏消息长度；C. 验证密文与关联数据的完整性

答案：C。AEAD 认证正文和上下文；防重放需要协议状态。

4. 理想 **256** 位哈希的经典通用碰撞量级？

A. 2^{256} ；B. 2^{128} ；C. 256 次

答案：B。生日攻击约为输出空间平方根。

5. **salt** 能否增加用户口令本身的秘密熵？

A. 能，等于 salt 的位数；B. 不能，但能区分记录与降低预计算摊销；C. 能，只要 salt 保密

答案：B。salt 通常公开，不阻止针对单账户枚举口令。

6. 裸 **RSA** 为何不满足普通 **CPA** 保密？

A. 因为没有逆运算；B. 因为密钥必须公开；C. 因为是确定性的，可加密候选并比较

答案：C。随机化安全编码是实际公钥加密的一部分。

7. 未经认证的 **DH** 主要会遇到什么？

A. 中间人替换公开值；B. 任何监听者都能马上算指数；C. 只能使用对称密码

答案：A。DH 困难性不能自动认证交换对端身份。

8. 同一 **nonce** 在 **GCM** 中重用的后果？

A. 只影响输出美观；B. 可能破坏保密与认证；C. 只降低一点速度

答案：B。流与认证关系都会暴露，不能用更长密钥补救。

9. Schnorr 两条签名重用 r 且挑战不同，会怎样？

A. 私钥可由两式相减恢复；B. 签名更快且仍安全；C. 公钥会自动撤销

答案：A。 r 被消去，求逆后获得私钥 x 。

10. 不足门限的 Shamir 份额隐藏秘密，依赖什么？

A. 随便使用整数除法；B. 系数均匀、有限域和份额位置正确；C. 只要分成多份即可

答案：B。秘密分享有精确的代数与随机性条件。

11. LWE 中误差太大主要会导致什么？

A. 合法解密可能失败；B. 自动达到无限安全；C. 不需要密钥

答案：A。噪声必须同时满足正确性和安全参数条件。

12. QKD 是否消除了经典身份认证的需要？

A. 是，因为使用光子；B. 否，仍需要认证经典交流；C. 是，只要观察不到错误

答案：B。否则中间人仍可分别与两端建立密钥。

进阶阅读方法

第一次读标准先找 scope、接口、输入约束与测试向量；第二次核对错误处理与参数限制；第三次读安全考虑和引用的证明。对论文先找定义、假设与定理，再看归约。不要把不同论文里名字相同的“安全”默认理解为同一个定义。

练习与参考答案

1. 如果自测全部正确，下一步怎样深化？

参考答案

不看正文重建三个证明：OTP 完美保密、RSA 正确性、Schnorr 特殊可靠性。再独立设计一个包含 nonce 管理、防回滚和权限边界的应用方案。

资料与标准 · 阅读入口

规范给出精确接口，教材帮助建立直觉与证明。

正文是原创教学解释与小参数算例；以下是核对规范和深入学习的一手资料，不是全文转载。参考资料核对日期：2026-10-03。标准与软件可能继续修订，部署前应查官方状态、勘误和当前库版本。数学背景以通用定义和独立推导为主。

[1] NIST · FIPS 197 — Advanced Encryption Standard

第 06 章：AES 的参数与结构。2023 年更新为编辑性改进。

[2] NIST · SP 800-38D — GCM and GMAC

第 09 章：GCM 定义与使用条件。实施时检查修订与勘误。

[3] RFC 8439 · ChaCha20 and Poly1305

第 05、09 章：IETF 版本的算法布局、AEAD 与测试向量。

[4] RFC 8446 · TLS 1.3 (2018 年教学参考)

第 16 章：学习握手、密钥派生、记录层与早期数据。部署需查状态页及后续更新。

[5] RFC 5869 · HKDF

第 10 章：Extract/Expand、上下文与长度限制。

[6] RFC 9106 · Argon2

第 10 章：内存困难性、Argon2id 与参数选择。

[7] RFC 8032 · EdDSA

第 15 章：Ed25519 等实例、编码与验证细节。

[8] NIST · FIPS 203 — ML-KEM

第 22 章：模块格密钥封装；查看页面上的潜在更新/勘误。

[9] NIST · FIPS 204 — ML-DSA

第 22 章：模块格数字签名。

[10] RFC 9180 · HPKE

第 11 章：KEM/KDF/AEAD 组合与不同认证模式；这是 IRTF 信息性 RFC。

[11] RFC 8017 · PKCS #1

第 12 章：RSA-OAEP、RSA-PSS 与编码约束。

[12] cryptography · Authenticated encryption 官方 API 文档

第 19 章：AESGCM 高层接口与 InvalidTag 行为；stable 页面会随版本更新。

[13] NIST · FIPS 205 — SLH-DSA

第 22 章：无状态哈希数字签名。

[14] Bennett & Brassard · BB84 原始论文

第 23 章：1984 年论文的公开归档，不把归档上传年份当作发明年份。

[15] Shor & Preskill · Simple Proof of Security of BB84

第 23 章：量子密钥分发的重要安全证明路径。

[16] Boneh & Shoup · A Graduate Course in Applied Cryptography

深化教材：对称密码、公钥密码、安全协议以及数论、概率与复杂性附录。

[17] RFC 7748 · Elliptic Curves for Security

第 13—14 章延伸：X25519/X448、编码和共享结果处理。

附录放在本文件最后，便于按正文需要回查。先读与当前章节相关的部分即可，无需在开始之前全部背完。

附录 A · 符号、集合、逻辑与证明

阅读形式化定义的第一步，是把符号翻译成完整句子。

A.1 常见符号

符号	读法与含义	例子
$\in, \notin$	属于、不属于	$3 \in \mathbb{Z}$; $1/2 \notin \mathbb{Z}$
$\forall, \exists$	对所有、存在	$\forall x \in \mathbb{Z}, \exists y \in \mathbb{Z} : y = x + 1$
$\wedge, \vee, \neg$	且、或、非	条件同时成立、至少一个成立、取反
$\Rightarrow, \Leftrightarrow$	蕴含、当且仅当	充分条件、双向等价
$ S $	集合元素个数	$ \{0,1\}^n = 2^n$
$\leftarrow$	赋值或按说明采样	$b \leftarrow \{0,1\}$ 通常表示均匀取一位
$\parallel, \oplus$	串拼接、逐位异或	$01 \parallel 10 = 0110$; $01 \oplus 10 = 11$
$\perp$	失败或拒绝	认证失败输出 $\perp$
$\lfloor x \rfloor, \lceil x \rceil$	向下、向上取整	$\lfloor 2.7 \rfloor = 2$; $\lceil 2.7 \rceil = 3$
$\mathbb{Z}, \mathbb{R}, \mathbb{C}, \mathbb{F}_q$	整数、实数、复数、q 元有限域	域存在需要 q 为素数幂

A.2 量词的顺序

“对每个密文存在一个能解开它的密钥”不等于“存在一把密钥能解开所有密文”。 $\forall c \exists k$ 与 $\exists k \forall c$ 的含义不同。安全定义中，“对每个有效攻击者，存在可忽略函数”也要留意参数与函数依赖关系。

A.3 函数与映射

$f: X \rightarrow Y$ 表示给每个 $x \in X$ 唯一输出 $f(x) \in Y$ 。单射：不同输入输出不同；满射：每个 Y 元素都有原像；双射：同时满足，存在逆函数。分组密码在固定密钥下要求双射；哈希输入空间大于输出空间，不可能对全部输入单射。

A.4 四种证明方法

- 直接证明：从前提通过等式与定义推出结论，如 OTP 两次异或恢复。
- 反证法：假设结论不成立，推出矛盾。
- 逆否命题：证明 $\neg B \Rightarrow \neg A$ ，与 $A \Rightarrow B$ 等价。

- 归纳法：证明基础情形，再证明 n 成立推出 $n+1$ 成立。

反例能推翻全称命题。例如“每个奇数都是素数”，9 就足够。检验一百万个样本未出错，不能替代对所有输入

A.5 不可能性与鸽巢原理

若把超过 N 个对象放进 N 个盒子，至少一盒包含两个。固定 n 位哈希只有 2^n 个输出，因此对任意 2^n+1 个不同输入必有碰撞。密码安全从来不是碰撞不存在，而是攻击者难以找到有用碰撞。

A.6 证明阅读清单

圈出前提、量词、结论与使用的定理。每次出现除法，问分母是否可逆；每次出现概率，问随机性来自哪里；每次出现“忽略”，问省略项是否有界。掌握这一习惯后，安全证明会比直接背公式更容易读。

练习与参考答案

1. “所有安全方案都正确”能否推出“所有正确方案都安全”？

参考答案

不能，这是把蕴含反过来了。裸 RSA 等方案可以满足正确性却不满足所需保密安全。

2. 为什么一个 256 位哈希不可能给所有消息唯一编号？

参考答案

输出只有 2^{256} 种，输入长度不限，输入集合更大。鸽巢原理保证碰撞存在。

附录 B · 代数运算、指数与对数

数量级理解，决定你能否正确比较攻击成本。

B.1 运算顺序与分数

先括号，再乘方，再乘除，最后加减。 $a/(bc)$ 与 $(a/b)c$ 不同。模域里的“除”另有含义，必须先找到逆元，不能把普通分数直接四舍五入。二进制整数如 $1101_2=1\times 8+1\times 4+0\times 2+1=13$ 。

B.2 指数规则

$$a^u a^v = a^{u+v} ; (a^u)^v = a^{uv} ; a^0 = 1 (a \neq 0) ; a^{-u} = 1/a^u$$

密码中的 2^{128} 是可能性数量，128 是其二进制对数。每增加一位均匀密钥，穷举空间翻倍；增加 10 位约乘 1024。每秒 10^{12} 次操作，遍历 2^{128} 也仍远超普通时间尺度，但真实攻击可能利用结构、侧信道或弱口令，不能只算穷举。

B.3 对数是指数的逆

$$\begin{aligned} \log_2(2^x) &= x ; \log_2(ab) = \log_2 a + \log_2 b \\ \log_2(a^t) &= t \log_2 a ; \log_2 a = \ln(a)/\ln(2) \end{aligned}$$

六位十进制串有 10^6 种， $\log_2 10^6 \approx 19.93$ 。一个有 2048 个可能值的均匀秘密只有 11 位熵。若密码从字典取一个词，不能用键盘字符集大小乘长度来估计真实分布。

B.4 和与积

$\sum_{i=1}^n a_i$ 表示把 n 项相加； $\prod$ 表示相乘。 $1+\dots+(q-1)=q(q-1)/2$ ，生日界里的两两组合数量来自这个式子。等比和 $1+r+\dots+r^{n-1}=(r^n-1)/(r-1)$ ， $r \neq 1$ 。

B.5 近似与不等式

对很小的 x ， $\ln(1-x) \approx -x$ ， $e^{-x} \approx 1-x$ 。因此 $1-e^{-x} \approx x$ ，但 x 大时不能继续使用线性近似。生日碰撞概率若已接近 1，再用 $q^2/(2N)$ 会得到超过 1 的“概率”，这说明近似超出适用范围。

B.6 科学计数法与误差

1.2×10^{-9} 是一个十亿分之一数量级。相对误差 = $|\text{估计} - \text{真实}|/|\text{真实}|$ ；绝对误差 = $|\text{估计} - \text{真实}|$ 。密码中的有限域运算要求精确，不能用浮点近似计算模逆或签名。生日概率和性能估计可以使用浮点，但要标注近似与范围。

B.7 微积分要学到什么程度

基础密码算法不要求熟练微积分。若读误差估计、概率尾界与连续分布，理解极限、导数和积分会有帮助。例如 $d \ln x/dx=1/x$ 可用于推导 $\log$ 近似，积分可描述连续概率密度。进阶研究再系统补齐，不应让微积分成为第一次理解 XOR 的门槛。

练习与参考答案

1. 均匀 8 位秘密与均匀 16 位秘密，空间差多少倍？

参考答案

分别为 2^8 和 2^{16} ，差 $2^8=256$ 倍，不是两倍。

2. 若 $N=10^6$ 、 $q=100$ ，生日碰撞概率的稀疏近似是多少？

参考答案

$q(q-1)/(2N)=9900/2000000=0.00495$ ，约 0.495%；更完整指数近似约 0.4938%。

附录 C · 整除、同余、逆元与中国剩余定理

这是 RSA、DH 和有限域算术的基础。

C.1 整除与素数

$a|b$ 表示存在整数 k 使 $b=ak$ 。正整数 $p>1$ 只有 1 和自身两个正因子时是素数。1 不是素数。每个大于 1 的整数可唯一分解为素数乘积，除排列顺序外唯一。

C.2 同余

$a \equiv b \pmod n$ 表示 $n|(a-b)$ ，也就是二者余数相同。 $17 \equiv 2 \pmod 5$ ， $-1 \equiv 4 \pmod 5$ 。同余可加、减、乘和取非负整数幂，但不能随意除。例如 $2 \times 1 \equiv 2 \times 4 \pmod 6$ ，不代表 $1 \equiv 4$ ；因子 2 没有模 6 的逆元。

C.3 最大公因数与 Euclid 算法

$\gcd(a,b)$ 是共同因子的最大值。反复取余保持 $\gcd$ ： $\gcd(a,b)=\gcd(b,a \bmod b)$ 。例：
 $3120=17 \times 183+9$ ； $17=9+8$ ； $9=8+1$ ； $8=8 \times 1+0$ ，所以 $\gcd(3120,17)=1$ 。

C.4 扩展 Euclid 与逆元

回代得到 $1=9-8=2 \times 9-17=2 \times 3120-367 \times 17$ 。因此 -367 是 17 模 3120 的逆元，归一化为 2753。一般 $\gcd(a,n)=1$ 时存在 $x、y$ 使 $ax+ny=1$ ，于是 $ax \equiv 1 \pmod n$ 。反过来，存在逆元也意味着互素。

小例： $7^{-1} \pmod{11}=8$ ，因为 $7 \times 8=56 \equiv 1$ 。模 11 中 $3/7$ 表示 $3 \times 8 \equiv 2$ ；不是实数 0.428...

C.5 φ 函数与 Euler 定理

$\varphi(n)$ 数出 1 到 n 中与 n 互素的整数数量。素数 p 有 $\varphi(p)=p-1$ ；不同素数 $p、q$ 的乘积有 $\varphi(pq)=(p-1)(q-1)$ 。若 $\gcd(a,n)=1$ ，则 $a^{\varphi(n)} \equiv 1 \pmod n$ ；素数情形是 Fermat 小定理 $a^{p-1} \equiv 1 \pmod p$ 。互素前提不可省略。

C.6 CRT

若 $n_1、n_2$ 互素，给定 $x \equiv a_1 \pmod{n_1}$ 与 $x \equiv a_2 \pmod{n_2}$ ，可唯一确定 $x \pmod{n_1 n_2}$ 。例 $x \equiv 2 \pmod 3$ 、 $x \equiv 3 \pmod 5$ ，得 $x \equiv 8 \pmod{15}$ 。可把一个大模数问题拆为若干小问题，RSA 私钥加速会用到。

通用构造： $N=n_1 n_2$ ， $N_1=N/n_1$ ， $N_2=N/n_2$ ；找 $u_i=N_i^{-1} \pmod{n_i}$ ，则 $x=a_1 N_1 u_1 + a_2 N_2 u_2 \pmod N$ 。因为每项在自己的模数下贡献目标余数，在另一模数下为零。

C.7 素性测试与分解不是同一问题

判断一个数是否素数，与把合数分解出因子，是不同任务。现代系统能够高效产生大素数，不意味着能高效

分解两个大素数的乘积。概率素性测试要正确处理随机性、轮数与输入；不应根据几个简单整除检查就生成生产 RSA 参数。

练习与参考答案

1. 求 $5^{-1} \bmod 17$ ，并算 $3/5 \bmod 17$ 。

参考答案

$5 \times 7 = 35 \equiv 1$ ，所以逆元为 7； $3 \times 7 = 21 \equiv 4$ 。

2. 解 $x \equiv 1 \bmod 4$ 、 $x \equiv 2 \bmod 7$ 。

参考答案

$x=9$ 满足二者，所有解为 $9+28k$ 。CRT 在互素模数下给出模 28 的唯一解。

3. 是否能对 $a=3$ 、 $n=9$ 直接用 $a^{\varphi(n)} \equiv 1$ ？

参考答案

不能， $\gcd(3,9) \neq 1$ 。 $\varphi(9)=6$ ， $3^6 \equiv 0 \bmod 9$ ，不是 1。

附录 D · 概率、条件分布与统计距离

安全是对随机过程的陈述，必须说清概率空间。

D.1 样本空间与随机变量

样本空间 Ω 包含可能结果，事件 A 是其中一组结果。均匀抽 n 位串时，每串概率 2^{-n} 。随机变量 X 把结果映射为数值或对象；“密文 C ”也可视为随机变量，因为密钥、加密随机性或消息分布变化。

D.2 条件概率与独立

$$\Pr[A|B] = \Pr[A \cap B] / \Pr[B] \quad (\Pr[B] > 0)$$

独立意味着 $\Pr[A \cap B] = \Pr[A]\Pr[B]$ 。边际上看似随机，不代表与别的变量独立：令 X 为均匀比特、 $Y=X$ ，则 X 、 Y 各自均匀，却完全相关。OTP 要求密钥与消息独立，不能仅确认密钥频率各半。

D.3 Bayes 与全概率

$$\Pr[A|B] = \Pr[B|A]\Pr[A] / \Pr[B]$$

$$\Pr[B] = \sum_i \Pr[B|A_i]\Pr[A_i]$$

这里 A_i 应构成不重叠且覆盖空间的划分。安全观察会更新攻击者的先验。完美保密的核心是更新后与更新前完全相同，而不是“攻击者一开始什么也不知道”。

D.4 期望与方差

$E[X] = \sum_x x \Pr[X=x]$ ， $\text{Var}(X) = E[(X - E[X])^2]$ 。期望具有线性性，即便随机变量不独立也有 $E[X+Y] = E[X] + E[Y]$ 。方差相加通常需要相应独立或协方差条件。一次实验没碰撞，不表示期望风险为零。

D.5 并集界

$$\Pr[\cup_i A_i] \leq \sum_i \Pr[A_i]$$

不需要独立。若每次失败概率至多 ϵ ，一百万次的总失败概率最多一百万 ϵ （并以 1 为上界）。这是安全证明经常累积坏事件的方法，可能松但便于使用。不要误把不同事件概率相加的上界当精确值。

D.6 总变差距离

$$\Delta(P, Q) = \frac{1}{2} \sum_x |P(x) - Q(x)|$$

它度量两分布最大事件概率差。均匀比特 $P=(0.5,0.5)$ ，偏置比特 $Q=(0.6,0.4)$ ，距离为 0.1。统计不可区分控制这个距离；计算不可区分只约束有效算法的可见差异，不一定控制无限算力下的距离。

D.7 生日界与样本相关性

生日公式的简单推导假设独立均匀采样。若随机数源偏置或复制状态，碰撞风险可能更高。对每对采样定义“相等”事件，其概率为 $1/N$ ， $q(q-1)/2$ 对的并集界得到 $q(q-1)/(2N)$ 。指数公式是更准确的近似，并非适用于任意相关输出。

D.8 尾界的入门

非负 X 的 Markov 不等式： $\Pr[X \geq t] \leq E[X]/t$ 。Chebyshev： $\Pr[|X - E[X]| \geq t] \leq \text{Var}(X)/t^2$ 。更强的 Chernoff/Hoeffding 界需要特定独立性和有界条件，适合样本误差分析。QKD 的抽样与参数估计必须把有限样本置信界计入，不能只看观察到的误码百分比。

练习与参考答案

1. X 为均匀位， $Y=X$ ，是否有 $\Pr[X=0, Y=0]=1/4$ ？

参考答案

没有，实际为 $1/2$ ；两个变量不独立。各自均匀不保证联合独立。

2. 每次验证接受随机伪造的概率至多 2^{-32} ，最多 10^6 次尝试，并集上界？

参考答案

至多 $10^6/2^{32} \approx 0.00023283$ ，约 0.0233%。这还不包括结构攻击等其他风险项。

附录 E · 群、环、有限域与多项式

同样叫加法和乘法，在不同代数结构里有不同规则。

E.1 群

群由集合 G 与运算组成，满足封闭、结合律、单位元和每个元素有逆元。交换群还满足交换律。整数加法是群；整数乘法不是群，因为 2 没有整数乘法逆元。密码文献常用乘法记号 g^a ，也常用加法记号 $[a]G$ ，它们表达重复的群运算。

E.2 阶与循环群

群的阶是 $|G|$ ；元素 g 的阶是最小正整数 q 使 $g^q=1$ 。若 $G=\{1,g,\dots,g^{q-1}\}$ ， g 是生成元， G 为循环群。Lagrange 定理说有限群元素阶整除群阶。在素数 p 下，非零元素乘法群阶 $p-1$ ；可在其中选择素数阶子群用于密码学。

E.3 环与域

环具有加法与乘法及分配律；域进一步要求每个非零元素乘法可逆。 $\mathbb{Z}/n\mathbb{Z}$ 在合数 n 下通常有零因子：模 6 中 $2 \times 3 = 0$ 。模素数 p 的 $\mathbb{F}_p$ 是域。域内可做消元与除法，前提是除数非零。

E.4 多项式

多项式 $a_0+a_1x+\dots+a_dx^d$ 的系数可以在任意域中。加法逐项，乘法做卷积。在 $\mathbb{F}_2$ 中 $1+1=0$ ，所以 $(x+1)^2=x^2+1$ 。注意这不是实数多项式里的普通展开结果。

E.5 $\mathbb{GF}(2^8)$

把 8 位字节写成次数低于 8 的二元多项式。用不可约多项式 $P(x)=x^8+x^4+x^3+x+1$ 对乘积取余，就得到 256 元域。加法为 XOR，乘法不是普通整数乘法。不可约意味着 P 不能分成更低次数的非平凡多项式乘积，从而保证非零元素可逆。

约化过程： $0x83 = x^7+x+1$ 。乘 x 得 x^8+x^2+x 。因为 $x^8 \equiv x^4+x^3+x+1$ ，消去最高项后得到 $x^4+x^3+x^2+1=0x1d$ 。二元域里减法与加法相同。

E.6 插值

域上次数小于 t 的多项式由 t 个横坐标不同的点唯一确定。Lagrange 插值：

$$f(x) = \sum_i y_i \cdot \prod_{j \neq i} (x - x_j) / (x_i - x_j)$$

分母非零且可逆。把 $x=0$ 代入就恢复 Shamir 分享的秘密。不足 t 个点留下自由系数，随机性使观察者不能确定常数项。

E.7 多项式环与 NTT

格方案常在如 $\mathbb{Z}_q[x]/(x^n+1)$ 的商环中操作，把高次项按 $x^n=-1$ 折回，产生负循环卷积。NTT 用模域的单位根加速特定多项式运算，类似 FFT 的代数形式但使用精确模算术。可用根与变换结构由 n 、 q 和具体规范决定；不能把浮点 FFT 代码直接当作标准 NTT。

练习与参考答案

1. 模 7 的非零元素是否都有乘法逆元？模 8 呢？

参考答案

模 7 是素域，全部有。模 8 中 2、4、6 与 8 不互素，没有逆元；例如 $2 \times 4 \equiv 0$ 。

2. F_2 中 $(x+1)^2$ 是什么？

参考答案

x^2+2x+1 ，但 $2=0$ ，因此 x^2+1 。

3. 插值为何要求横坐标不同？

参考答案

否则 $x_i - x_j = 0$ 不能求逆，而且重复同一个位置不提供新的独立约束。

附录 F · 信息论与熵

“有多少不确定性”比“字符串看上去多复杂”更精确。

F.1 Shannon 熵

$$H(X) = -\sum_x p_x \log_2 p_x, \text{ 约定 } 0 \log 0 = 0$$

均匀 N 种值的熵为 $\log_2 N$ 。均匀比特熵为 1；偏置位 $p=0.9$ 的熵约 0.469。熵测量平均不确定性；它不直接等于最优攻击必须计算的次数，还要考虑分布、验证成本和猜测策略。

F.2 条件熵与互信息

$$H(X|Y) = \sum_y \Pr[Y=y] H(X|Y=y)$$

$$I(X;Y) = H(X) - H(X|Y)$$

I 描述观察 Y 减少多少关于 X 的不确定性。完美保密可表示 $I(M;C)=0$ 。若密文总是附带明文长度，而消息长度随机，长度这部分仍有泄露；OTP 的常见证明固定了消息长度。

F.3 最小熵

$$H_\infty(X) = -\log_2(\max_x \Pr[X=x])$$

它强调最容易猜中的值。若 50% 用户使用同一个口令，最小熵仅 1 位，即便另一半选择巨大空间。Shannon 熵可能仍显得较大，不能掩盖大量账户可被一次猜中。

F.4 确定函数不能凭空增加秘密

如果 $Y=f(X)$ ，把弱口令哈希成 256 位，可能输出长度变长但秘密来源没有增加。攻击者可枚举 X 的候选得到 Y 。带独立随机性或公开 seed 的提取器可以从满足条件的高熵源提取近均匀秘密，但不能从已完全公开的输入制造秘密。

F.5 隐私放大的直觉

假设共享串 X 还有足够的、相对于对手信息 E 的条件最小熵。使用合适的通用哈希族并公开选择 seed，可压缩成较短、近均匀的密钥。典型 leftover-hash 型界要求输出长度比剩余熵短约 $2\log_2(1/\epsilon)$ 等安全余量，具体形式依经典/量子侧信息和熵定义而异。不是简单截取前 128 位。

F.6 信息泄露的组合

两个观察各自看似无害，联合起来可能泄露：若 X 为秘密、 R 为独立均匀掩码， R 和 $X \oplus R$ 单看都不泄露

X ，放在一起却可恢复 X 。这提醒我们评估日志、数据库和协议消息的联合分布，不只逐项检查。

F.7 安全参数与泄露预算

QKD 的公开纠错信息会减少剩余秘密熵，隐私放大必须扣除这部分；验证标签、参数估计错误与认证失败还会贡献安全误差。组合安全分析通常对这些误差做适当累积。理论安全不是一个脱离消息量和失败事件的形容词。

练习与参考答案

1. 均匀 1024 个可能值的秘密有多少位熵？

参考答案

$\log_2 1024 = 10$ 位。把它编码或哈希成 256 位不使秘密来源变成 256 位。

2. 公开 R 和 $C = X \oplus R$ 时， X 还保密吗？

参考答案

不保密， $X = C \oplus R$ 。掩码必须秘密；两个各自独立于 X 的边际观察，联合可能完全泄露 X 。

附录 G · 向量、矩阵、线性代数与格

理解 LWE 和量子态都需要线性代数，但两者使用的数域不同。

G.1 向量与内积

向量是有序分量，如 $v=(v_1, v_2, v_3)$ 。可逐分量相加、乘标量。实向量内积 $\langle u, v \rangle = \sum u_i v_i$ ；长度 $\|v\| = \sqrt{\langle v, v \rangle}$ 。复向量内积要把左边分量取复共轭。模域向量也有代数点积，但没有与实数欧氏长度完全相同的概念。

G.2 矩阵乘法

$m \times n$ 矩阵 A 乘 n 维列向量 s ，输出 m 维向量，第 i 项为 $\sum_j A_{ij} s_j$ 。乘法顺序一般不交换， AB 不一定等于 BA 。转置交换行列，复共轭转置记 $A^\dagger$ 。

$A=((1,2),(3,4))$, $s=(5,6)^T$
 $As=(17,39)^T$ ；在 F_{17} 中则为 $(0,5)^T$

G.3 线性独立、秩与基

若一组向量只有所有系数为零时才组合为零，则线性独立；基是能表达整个空间且独立的一组向量。秩是独立行或列的数量。满秩方阵可逆；非满秩方程可能无解或多解。模素数消元可进行求逆，合数模数下不能套用域内的所有除法规则。

G.4 解一个模线性系统

在 F_7 上， $x+2y=3$ 、 $3x+y=2$ 。第一式得 $x=3-2y$ ，代入第二式得 $9-5y=2$ ，即 $5y=0 \bmod 7$ 。5 有逆元，所以 $y=0$ ， $x=3$ 。无噪声的许多公开线性方程可解；这就是 LWE 要引入结构化噪声的重要直觉之一。

G.5 特征值与量子运算

$Av=\lambda v$ 表示 v 方向在 A 作用下只按 λ 缩放， v 为特征向量。Hermitian 矩阵 $A=A^\dagger$ 的特征值为实数，可描述量子可观测量；unitary 矩阵 $U^\dagger U=I$ 保持内积，可描述封闭量子系统的可逆演化。不要把“可逆矩阵”与“unitary”视为同义，后者还要保持长度。

G.6 格

$L(B)=\{Bz : z \in \mathbb{Z}^n\}$

把整数向量映射到欧氏空间，得到离散格点。基 B 与 B' 可能生成同一个格，但基向量长短与夹角不同，计算便利程度也不同。二维可画图直观理解；密码用高维格，几何困难性不能凭二维经验直接判断。

G.7 SVP、CVP 与 LWE

SVP 找最短非零格向量，CVP 找最接近目标的格点。密码学常使用特定近似版本、分布与归约条件。LWE 与格困难性有重要理论联系，但参数、范数、最坏情形/平均情形和量子/经典归约的细节不能省略后直接说“与所有最短向量问题等价”。

练习与参考答案

1. 矩阵乘法 AB 能否总换成 BA ？

参考答案

不能；尺寸可能不兼容，即使兼容也通常不相等。密码和量子运算中的顺序有意义。

2. LWE 中把误差 e 设置为零会怎样？

参考答案

在足够独立样本与合适条件下， $As=b$ 可通过线性代数恢复 s ，失去噪声所提供的困难性结构。

附录 H · 复杂性、归约与混合论证

学习如何把“我认为很难”转成有条件、可检查的结论。

H.1 输入长度

数值 N 约需要 $\log_2 N$ 个比特表示。因此“运行 N 次”可能对输入长度是指数时间。多项式时间如 $O(n^3)$ ，指数时间如 $O(2^n)$ 。有限参数下常数与实现也重要：理论多项式不保证现实快。

H.2 P、NP 与密码困难性

P 是可在确定性多项式时间内判定的语言类； NP 有可在多项式时间验证的证据。 $P \neq NP$ 尚未解决。即便它成立，也不自动得到密码学所需的平均情形困难问题或具体安全参数。最坏情形有少数难实例，不代表系统随机生成的实例很难。

H.3 PPT

概率多项式时间算法可用随机比特，并在安全参数的多项式时间内完成。安全定义约束所有这样的对手。密码方案也需高效，因此同时追求诚实参与者可算、缺秘密的对手不可算。

H.4 归约方向

要证明攻击方案很难，通常把难题实例交给 B ， B 调用假设存在的方案攻击者 A 求解难题。方向是“若可攻破方案，则可解决假定困难问题”。反方向“解难题可以攻破方案”仅说明一种攻击途径，不足以排除其他攻击。

H.5 混合论证

构造游戏 $G_0, G_1, \dots, G_t$ ，每次只替换一小块，例如把 PRF 输出换成随机函数。若相邻游戏的可区分优势至多 ϵ_i ，由三角不等式，端点差异至多 $\sum \epsilon_i$ 。最后游戏若独立于挑战位，就可界定真实游戏优势。

流加密思路：真实游戏用伪随机流；混合游戏换成均匀掩码，成为一次一密。在输入不重用等条件下，若攻击者能区分明文，也可用它区分伪随机流与真随机。多消息场景还要严谨处理查询、nonce 与碰撞事件。

H.6 坏事件与具体界

先定义 nonce 碰撞等坏事件 B ，再证明 B 未发生时游戏相近，最终加上 $\Pr[B]$ 。若界形如 $\text{Adv} \leq \text{Adv_PRF} + q(q-1)/2^{97}$ ，不可只引用第一项“PRF 很安全”而忽略系统调用量 q 。

H.7 随机预言机与标准模型

随机预言机对每个新输入生成随机输出，对重复输入返回同值；对手与归约均可查询。标准模型不引入这种理想随机函数。两者中的证明假设不同，不能仅看“有证明”三个字。量子可查询随机预言机还需处理叠加查

询，经典证明不一定直接延续。

H.8 计算模型的边界

经典安全允许经典多项式对手；后量子安全允许相应量子对手；泄露抵抗模型额外规定可泄露多少信息。选择更强模型会改变算法、证明和参数。不存在一个未加限定的“理论上安全”能覆盖所有物理与系统风险。

练习与参考答案

1. 一个攻击者以 ϵ 优势破坏方案，归约损失 $L=100$ ，能保证难题算法至少多少优势（忽略其他项）？

参考答案

至少 $\epsilon/100$ 。反推方案安全时，要乘上损失；归约不紧可能影响有限参数解释。

2. $P \neq NP$ 若被证明，能否直接宣布 RSA-2048 安全？

参考答案

不能。它不直接证明 RSA 的特定平均情形困难性或具体攻击成本，且没有覆盖实现和协议。

附录 I · 量子信息与物理基础

只补量子密码所需的核心，不把整套物理课程当成前置。

I.1 复数与概率幅

复数 $z=a+bi$ ， $i^2=-1$ ，共轭 $z^*=a-bi$ ，模平方 $|z|^2=a^2+b^2$ 。量子态的系数是概率幅，不是概率本身；测量概率来自模平方。幅可以相消产生干涉，普通非负概率不能这样相加抵消。

I.2 qubit

$$|\psi\rangle=\alpha|0\rangle+\beta|1\rangle; |\alpha|^2+|\beta|^2=1$$

$|0\rangle=(1,0)^T$ ， $|1\rangle=(0,1)^T$ 。Z 基测量得到 0 的概率是 $|\alpha|^2$ ，1 的概率是 $|\beta|^2$ 。叠加不等于可同时读出两个经典答案；一次测量只给一个结果，且一般改变后续状态。

I.3 基与测量

X 基为 $|+\rangle$ 、 $|-\rangle$ ，它们正交。测量 $|0\rangle$ 在 X 基的结果各半，因为 $\langle+|0\rangle$ 与 $\langle-|0\rangle$ 都有幅 $1/\sqrt{2}$ 。一般测量到基向量 $|u\rangle$ 的概率为 $|\langle u|\psi\rangle|^2$ 。对不兼容基的测量会使原本可预测的信息发生变化。

I.4 相位

全局相位 $e^{i\theta}|\psi\rangle$ 与 $|\psi\rangle$ 给出相同可观察预测；相对相位有物理影响。 $|+\rangle$ 与 $|-\rangle$ 的 Z 基结果都各半，却在 X 基可区分。这说明只看一个基下的概率不够描述完整量子态。

I.5 酉变换与 Hadamard

$$H=(1/\sqrt{2})\cdot((1,1),(1,-1))$$

$$H|0\rangle=|+\rangle; H|1\rangle=|-\rangle; H^2=I$$

酉矩阵保持长度和内积。多 qubit 空间用张量积， n 个 qubit 的态有 2^n 个幅，但这不表示能直接读出 2^n 个经典数。量子算法利用结构和干涉，让某些有用结果的测量概率增加。

I.6 纠缠

Bell 态 $(|00\rangle+|11\rangle)/\sqrt{2}$ 不能分解成两个独立纯态的张量积。两边 Z 基测量结果相关，但每边单独看仍各半随机。纠缠不允许控制测量结果来超光速传递消息；比较相关性仍需经典通信。

I.7 不可克隆的短证明

假设统一酉操作能对任意 $|\psi\rangle$ 复制： $U(|\psi\rangle|0\rangle)=|\psi\rangle|\psi\rangle$ 。同样能复制 $|\phi\rangle$ 。酉操作保持内积，所以 $\langle\psi|\phi\rangle$

$=(\langle\psi|\phi\rangle)^2$ 。对两个非正交且不同的态，内积既不是 0 也不是 1，这不成立。因此不存在对任意未知态都成功的统一完美复制器。已知态可制备，正交态可复制；不可克隆不是“任何东西都不能复制”。

I.8 密度矩阵

纯态密度矩阵 $\rho=|\psi\rangle\langle\psi|$ ；混态 $\rho=\sum_i p_i |\psi_i\rangle\langle\psi_i|$ 。它应为正半定 Hermitian 矩阵，迹为 1。测量算符 M_k 的结果概率可写为 $\text{Tr}(M_k \rho M_k^\dagger)$ 。混态能描述经典随机选择、环境耦合与子系统；不同制备方式可能得到相同 ρ 。

I.9 光子、偏振与噪声

光子的偏振可用于实现 qubit，例如两个正交线性偏振方向表示一组基；另一组旋转基表示另一组状态。信道损耗、暗计数、对准误差与多光子发射影响实际统计。单光子模型、弱相干脉冲和真实探测器不是同一个物理对象，需要在安全证明中对应建模。

I.10 不确定性不等于“观察就必定发现攻击”

测量影响与非正交态区分限制提供安全资源，但攻击可以是部分、相干、利用设备漏洞或伪装成噪声。安全要从观测统计与设备假设推导对手信息上界，再做隐私放大。没有完整分析就不能说“只要被偷看就一定报警”。

I.11 想进一步研究该补什么

量子信息路线：张量积、谱分解、密度矩阵、量子信道、熵与纠错。量子光学路线：波动、偏振、光源与探测、相干态和实验噪声。硬件安全路线：基本电路、功耗、电磁测量、信号处理与统计分析。经典密码学日常使用无需先掌握这些实验学科。

练习与参考答案

1. 测量 $|+\rangle$ 在 Z 基与 X 基，结果分别怎样？

参考答案

Z 基得到 0、1 各 1/2；X 基确定得到 +。这体现测量基决定可读信息。

2. $|+\rangle$ 与 $|-\rangle$ 的 Z 基概率相同，是否说明它们是同一个态？

参考答案

不是，相对相位不同；在 X 基测量可以区分。

3. 不可克隆定理是否禁止复制已知的 $|0\rangle$ ？

参考答案

不禁止。它禁止统一操作对任意未知量子态进行完美复制；已知态可以反复制备。